

Manual 03 - Implementacion del Marco de Gestion de Riesgos de IA de NIST

CANDIDATO CONTROLADO PARA QA DE PUBLICACION

Controlled source revision: 0c5e219dcca52266f6ea60d24fd16690df0de575 | Language: es-419 | NIST AI RMF 1.0 / NIST AI 100-1 baseline; version-aware and subject to source-watch controls.

Assurance boundary: This practical implementation manual does not certify an AI system, establish legal compliance, prove trustworthy-AI achievement, or provide an audit opinion.

Implementation paths and operating model

Manual 03 — Rutas de implementación del NIST AI RMF

Línea base controlada: NIST AI RMF 1.0 (NIST AI 100-1), con NIST AI 600-1 aplicado cuando la IA generativa está dentro del alcance.

Advertencia de versión: NIST indica que AI RMF 1.0 está siendo actualizado. Esta entrada de implementación está vinculada a la línea base actualmente publicada de AI RMF 1.0 y debe someterse a una revisión de impacto cuando NIST publique una revisión.

1. Seleccionar la ruta de implementación según el riesgo y la complejidad

No seleccione una ruta únicamente por la cantidad de empleados. Comience con la ruta menos compleja que todavía pueda controlar el riesgo real de IA de la organización, su ciclo de vida, las partes afectadas, la exposición regulatoria, el nivel de autonomía, la escala, la dependencia de terceros y las consecuencias potenciales.

Manual 03 memory graphic 1

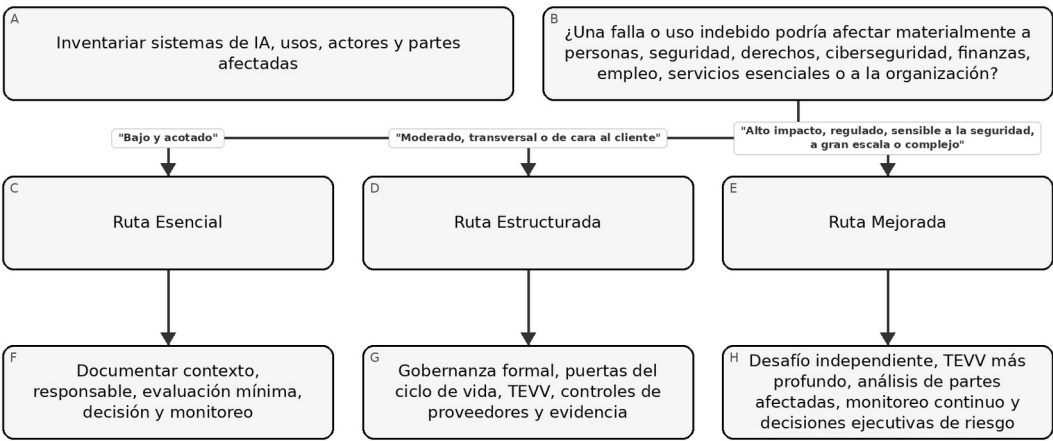


Figure 1. Implementation memory graphic

Explicación accesible: Primero se inventariarían los sistemas de IA y su contexto. Los usos de bajo riesgo y alcance limitado pueden comenzar con una ruta Esencial. Los usos moderados, transversales o de cara al cliente requieren una ruta Estructurada. Los usos de alto impacto, regulados, sensibles a la seguridad, a gran escala o complejos requieren una ruta Mejorada con mayor independencia, evaluación, monitoreo y autoridad para decidir. Una organización puede mover un sistema a una ruta más exigente cuando aumenten el riesgo o la incertidumbre.

Ruta	Contexto típico	Expectativa mínima de gobernanza
Esencial	Organización pequeña o uso de IA acotado con consecuencias limitadas y dependencias manejables	Responsable designado, inventario, contexto documentado, revisión básica de riesgo/impacto, uso aprobado, pruebas mínimas, orientación al usuario, monitoreo y ruta de incidentes
Estructurada	Organización mediana, IA de cara al cliente, varias unidades de negocio, dependencias materiales de datos/modelos o impacto moderado	Política/gobernanza formal de IA, revisión transversal, puertas del ciclo de vida, TEVV documentado, controles de proveedores, métricas, revisión de cambios e informes periódicos a la dirección
Mejorada	Empresa grande o compleja, uso regulado/sensible a la seguridad/de alto impacto, autonomía o escala sustancial o consecuencias severas	Gobernanza ejecutiva del riesgo, desafío independiente, TEVV más profundo, participación de partes afectadas, pruebas adversariales cuando corresponda, monitoreo continuo, autoridad sólida de contingencia/parada y aceptación documentada del riesgo residual

Escalone por encima de la ruta predeterminada cuando cualquiera de los siguientes factores sea material: niños o grupos vulnerables; empleo, crédito, salud, educación, seguridad, fuerzas del orden, servicios esenciales u otras decisiones de alto impacto; acciones autónomas; datos sensibles o de gran volumen; opacidad del modelo/proveedor; IA generativa o agéntica con acceso a herramientas; uso sensible desde el punto de vista de seguridad; amplia exposición pública; obligaciones legales o contractuales significativas; imposibilidad de revertir el daño; o evidencia débil sobre el desempeño.

2. Construir un único ciclo operativo alrededor de GOVERN, MAP, MEASURE y MANAGE

Las funciones principales se refuerzan mutuamente y no constituyen una secuencia de una sola vez. La gobernanza debe influir en todas las demás funciones, y la nueva evidencia proveniente de medición u operación debe actualizar el contexto y las decisiones de gestión.

Manual 03 memory graphic 2

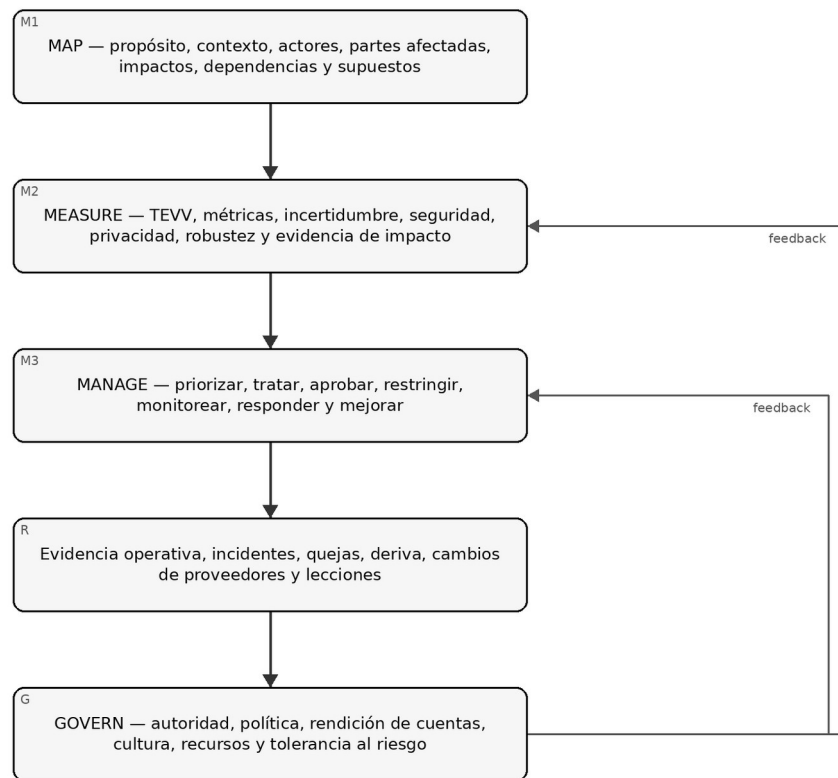


Figure 2. Implementation memory graphic

Explicación accesible: GOVERN establece la rendición de cuentas y la autoridad de decisión durante todo el ciclo de vida. MAP describe el contexto real y los posibles impactos. MEASURE produce evidencia mediante pruebas, evaluación, verificación, validación, métricas y otros análisis. MANAGE utiliza esa evidencia para priorizar y tratar el riesgo y tomar decisiones operativas. La evidencia operacional, los incidentes, las quejas, la deriva y los cambios de proveedores retroalimentan la gobernanza y una nueva evaluación del contexto y de las mediciones.

Ciclo operativo Esencial

1. Designar al responsable del negocio/sistema y al contacto técnico responsable.
2. Registrar propósito, usuarios, partes afectadas, datos, modelo/proveedor, función en la decisión y usos prohibidos.
3. Identificar beneficios plausibles, daños, uso indebido, problemas de seguridad/privacidad, riesgos de dependencia e incertidumbre.
4. Probar el sistema frente a un conjunto pequeño pero pertinente de criterios de aceptación antes del uso aprobado.
5. Documentar la decisión: aprobar, aprobar con condiciones, piloto, restringir o no utilizar.
6. Proporcionar a los usuarios instrucciones claras, expectativas de verificación, escalamiento y condiciones de parada.
7. Monitorear fallas clave, quejas, incidentes, cambios de proveedor/modelo y deriva material.
8. Reevaluar después de un cambio material o cuando exista evidencia de que los supuestos eran incorrectos.

Ciclo operativo Estructurado

Agregar a la ruta Esencial:

- gobernanza transversal y propiedad del riesgo;
- criterios de riesgo y autoridades de decisión documentados;
- puertas del ciclo de vida para ingreso, diseño/adquisición, evaluación, despliegue, operación, cambio y retiro;
- plan TEVV documentado con datos representativos y umbrales explícitos;
- control de versiones y linaje de modelos, datos y proveedores;

- revisiones de privacidad, ciberseguridad, accesibilidad, supervisión humana y partes afectadas cuando corresponda;
- debida diligencia de proveedores y requisitos contractuales/de evidencia;
- procesos formales de incidentes/quejas y acciones correctivas;
- métricas de gestión y revisión periódica; y
- retención controlada de evidencia.

Ciclo operativo Mejorado

Agregar a la ruta Estructurada:

- supervisión ejecutiva o del consejo para riesgos materiales de IA;
- validación/desafío independiente proporcional a las consecuencias;
- pruebas de escenarios, estrés, adversariales, por subgrupos, de uso indebido y modos de falla según corresponda;
- evaluación más sólida de factores humanos y partes afectadas;
- controles explícitos de respaldo, reversión, apagado/parada, continuidad del negocio y alternativa manual;
- monitoreo continuo o casi continuo de riesgos operativos clave;
- aceptación formal del riesgo residual con vencimiento/condiciones de revisión;
- vigilancia reforzada de proveedores, subprocesadores y cambios de modelos;
- ejercicios para incidentes importantes de IA y comunicaciones; y
- análisis a nivel de portafolio de concentración, fallas correlacionadas y riesgo sistémico.

3. Convertir el Core en evidencia, no en burocracia

Toda decisión material de riesgo de IA debe dejar una cadena trazable desde el contexto hasta la evidencia y la acción.

Manual 03 memory graphic 3

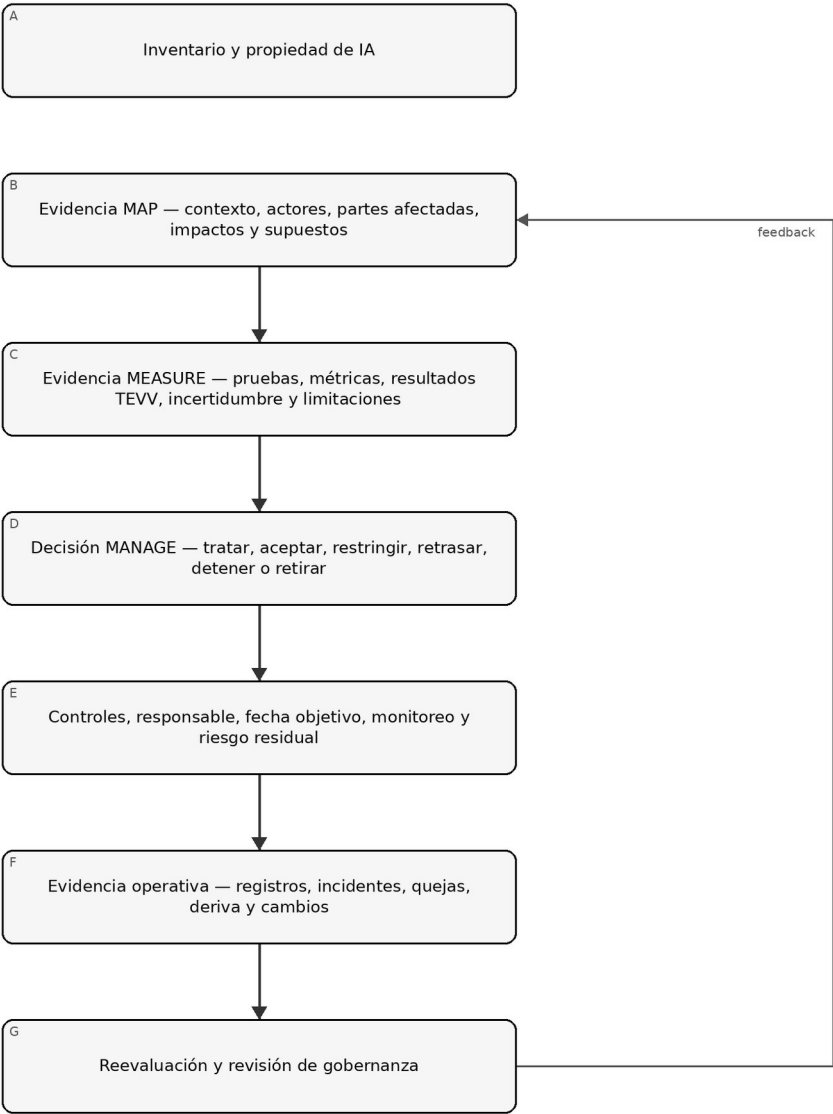


Figure 3. Implementation memory graphic

Explicación accesible: La evidencia comienza con un inventario de IA con responsable asignado, luego documenta contexto e impactos, pruebas e incertidumbre y la decisión de gestión resultante. Los controles y el riesgo residual se rastrean durante la operación. Registros, incidentes, quejas, deriva y cambios activan reevaluación y revisión de gobernanza. Una política por sí sola no demuestra que el riesgo haya sido controlado.

Registro mínimo de evidencia para un sistema material de IA:

Área de evidencia	Registro mínimo
Identidad	Nombre del sistema/uso, responsable, etapa del ciclo de vida, versión, proveedor/modelo, proceso de negocio y estado
Contexto	Propósito, usuarios, partes afectadas, geografía, escala, función en la decisión, dependencias y supuestos
Riesgo/impacto	Escenarios, beneficios, daños, uso indebido, severidad, probabilidad cuando sea significativo, incertidumbre y grupos

Área de evidencia	Registro mínimo
	afectados
Medición	Método de evaluación, población/datos, versión, umbrales, resultados, limitaciones, revisor y fecha
Tratamiento	Controles, condiciones, restricciones, supervisión humana, acciones de proveedores y remediación
Decisión	Aprobador autorizado, decisión de aprobar/restringir/pilotar/detener, riesgo residual, condiciones y vencimiento/activador de revisión
Operación	Medidas de monitoreo, quejas, incidentes, deriva, cambios de proveedor/modelo y evidencia de operación de controles
Mejora	Acción correctiva, nueva prueba, lecciones aprendidas y actualizaciones de gobernanza, contexto, mediciones o tratamiento

4. Aplicar NIST AI 600-1 cuando la IA generativa esté dentro del alcance

La IA generativa no debe tratarse como un sistema de gobernanza completamente separado. Aplique el modelo operativo general de AI RMF y luego agregue análisis y controles específicos de GenAI proporcionales al uso.

Como mínimo, evalúe cuando corresponda:

- confabulación o salida sin respaldo;
- contenido dañino, ilegal, inseguro o contrario a políticas;
- problemas de integridad y procedencia de la información;
- privacidad y exposición de datos sensibles;
- propiedad intelectual y origen del contenido;
- inyección de prompts, abuso de herramientas, envenenamiento de datos y otras amenazas de seguridad;
- extracción de modelos, abuso, agencia excesiva y automatización insegura;
- opacidad y riesgo de cambio de modelos fundacionales y proveedores de servicios externos;
- exceso de confianza humana, sesgo de automatización y revisión inadecuada;
- uso indebido a escala y habilitación de abusos;
- limitaciones de evaluación, contaminación de benchmarks y mala transferencia de pruebas a producción; y
- monitoreo de prompts, salidas y trazas con controles apropiados de privacidad y acceso.

Para GenAI agéntica o con uso de herramientas, agregue límites explícitos de autorización, mínimo privilegio, límites de transacción, puertas de confirmación, aislamiento de entornos, listas permitidas de herramientas, bloqueo de acciones de alto riesgo, registro, reversión y controles de parada de emergencia.

5. Integrar con la gobernanza existente en lugar de duplicarla

Manual 03 debe reutilizar sistemas de evidencia y decisión cuando sean adecuados para su propósito.

Capacidad existente	Integración con AI RMF
Gestión de riesgo empresarial	Criterios de riesgo de IA, agregación, aceptación de riesgo residual y escalamiento
Programa de seguridad / NIST CSF	Identidad, acceso, registros, vulnerabilidad, incidentes, resiliencia y cadena de suministro
Programa de privacidad	Propósito de datos, minimización, derechos, riesgo de privacidad, avisos, retención y quejas
Producto / SDLC	Requisitos, puertas del ciclo de vida, pruebas, liberación, cambio y retiro
Gobernanza de datos	Propiedad, calidad, procedencia, acceso, retención y linaje
Riesgo de proveedores	Debida diligencia de modelos/servicios, contratos, cambios, incidentes, evidencia y salida
Calidad / seguridad	Verificación, validación, análisis de fallas, acción correctiva y mejora continua

Capacidad existente	Integración con AI RMF
Auditoría interna / aseguramiento	Pruebas independientes de gobernanza, evidencia, diseño y operación de controles
ISO/IEC 42001	Estructura del sistema de gestión, operación documentada de controles, auditoría/revisión y mejora
Ley de IA de la UE / legislación sectorial	Aplicabilidad vinculante y obligaciones legales mantenidas separadas de la orientación voluntaria de NIST

No afirme que implementar AI RMF establece automáticamente conformidad con ISO/IEC 42001 o cumplimiento legal. Los crosswalks son herramientas para reutilizar evidencia, no declaraciones de equivalencia.

6. Definir puertas de decisión y condiciones de parada

Toda organización debe definir quién puede tomar decisiones materiales sobre IA y cuándo debe pausarse su uso.

Resultados típicos de decisión:

- Aprobar: la evidencia cumple los criterios actuales y el riesgo residual está dentro de la autoridad.
- Aprobar con condiciones: se permite un uso limitado con restricciones, monitoreo y vencimiento/revisión explícitos.
- Piloto: la incertidumbre es demasiado alta para un uso amplio; se aprueba un experimento acotado para generar evidencia.
- Remediar antes del uso: deben cerrarse primero brechas materiales de control o evidencia.
- Restringir: se reduce el alcance, población, autonomía, datos o funcionalidad.
- Detener/revertir: el daño real o plausible excede la tolerancia, fallan controles críticos o no puede demostrarse una operación segura.
- Retirar: el sistema se elimina y dependencias, datos, identidades, contratos y registros se gestionan mediante salida controlada.

Entre los activadores automáticos de revisión/parada deben incluirse incidentes graves; cambios materiales de modelo/proveedor; exposición no autorizada de datos; compromiso de seguridad; degradación material del desempeño o por subgrupos; salidas dañinas repetidas; quejas significativas; nuevas poblaciones o geografías afectadas; expansión hacia decisiones de alto impacto; pérdida de la supervisión humana requerida; evidencia de proveedor vencida; o una nueva obligación vinculante que afecte el uso.

7. Medir si la gestión del riesgo de IA está mejorando

Las métricas deben responder preguntas de gestión y no recompensar el volumen de documentación.

Ejemplos útiles:

- porcentaje de usos activos de IA reconciliados con un responsable y nivel de riesgo vigentes;
- tiempo desde ingreso/cambio material hasta una decisión de riesgo aprobada;
- porcentaje de sistemas materiales con evidencia de evaluación vigente vinculada a la versión desplegada;
- fallas de evaluación de alta severidad sin resolver y su antigüedad;
- incidentes, quejas, anulaciones, apelaciones y patrones repetidos de falla;
- medidas de deriva/desempeño/seguridad/privacidad vinculadas a umbrales de acción;
- porcentaje de proveedores críticos de IA con evidencia vigente y cambios materiales revisados;
- aprobaciones de riesgo residual o excepciones vencidas;
- acciones correctivas probadas nuevamente para verificar su eficacia dentro de objetivos basados en riesgo; y
- sistemas detenidos, restringidos o rediseñados porque la evidencia no respaldó continuar su uso.

Una métrica es útil únicamente cuando la dirección sabe qué decisión o acción debe activar.

8. Mantener la línea base actual sin cambiar silenciosamente el manual

Dado que NIST anunció una revisión de AI RMF, Manual 03 debe distinguir monitoreo de fuentes de adopción de fuentes.

Cuando NIST publique una nueva versión de AI RMF:

9. congelar el candidato de liberación vigente de Manual 03;
10. verificar la publicación final exacta de NIST y su estado de publicación efectivo;
11. comparar el nuevo marco con la línea base controlada de AI RMF 1.0;

12. clasificar los cambios como editoriales, terminológicos, estructurales, de resultados/acciones, implementación, crosswalk o impacto de aseguramiento;
13. identificar capítulos, plantillas, gráficos, traducciones y controles QA afectados;
14. actualizar primero la fuente controlada en inglés;
15. realizar revisión semántica humana de los cambios localizados;
16. regenerar los artefactos de publicación; y
17. publicar un historial de cambios claro en lugar de sobrescribir orientación anterior sin explicación.

Límite de aseguramiento: Aprobar la puerta del repositorio de Manual 03 validará la estructura controlada, estado de fuentes, accesibilidad y expectativas de evidencia. No certificará a una organización, determinará cumplimiento legal, garantizará una IA confiable, eliminará el riesgo ni constituirá una opinión de auditoría.

Controlled 32-chapter manual

1. Propósito de NIST AI RMF, límite voluntario y modelo de implementación

NIST AI RMF 1.0 es un marco voluntario y no sectorial para gestionar riesgos de IA y apoyar prácticas de IA confiables y responsables.

1.1 Qué significa implementar

Implementar significa incorporar decisiones de riesgo al trabajo normal de la organización. Una implementación útil de AI RMF conecta:

- estrategia y tolerancia al riesgo;
- inventario y propiedad de IA;
- puertas de producto, adquisición y ciclo de vida;
- análisis de partes afectadas y grupos de interés;
- evaluación técnica y no técnica;
- gobernanza de datos, modelos, software, infraestructura y proveedores;
- ciberseguridad, privacidad, seguridad, calidad y resiliencia;
- instrucciones para usuarios y supervisión humana;
- monitoreo, quejas y respuesta a incidentes;
- aceptación y escalamiento del riesgo residual; y
- acción correctiva, aprendizaje y retiro.

1.2 Qué no significa implementar

- Completar todas las sugerencias del Playbook sin considerar el contexto.
- Tratar todos los sistemas de IA como si tuvieran el mismo riesgo.
- Suponer que una puntuación alta en un benchmark demuestra desempeño aceptable en el mundo real.
- Tratar una declaración de un proveedor como evidencia suficiente para el contexto del cliente.
- Tratar el uso de AI RMF como cumplimiento legal, certificación ISO/IEC 42001 u opinión de auditoría.
- Afirmar que un sistema es “confiable” porque existe un documento de gobernanza.

1.3 Una unidad práctica de rendición de cuentas

Utilice el registro de sistema/uso de IA como unidad mínima que conecta la gobernanza con la operación. Un registro puede cubrir un servicio o caso de uso estrechamente controlado, pero no agrupe usos no relacionados cuando sus partes afectadas, consecuencias de decisión, modelos, datos, configuraciones, proveedores o propietarios de riesgo difieran materialmente.

Campo	Contenido mínimo
Identidad	Nombre del sistema/uso, ID único, responsable, proceso de negocio y estado del ciclo de vida
Propósito	Tarea prevista, función de decisión/contenido, usuarios y beneficio esperado
Alcance	Geografía, población, escala, autonomía y usos prohibidos
Tecnología	Modelo/servicio, versión, software, herramientas, infraestructura e integraciones
Datos	Entradas, salidas, datos sensibles, fuentes, retención y linaje principal
Partes	Actores de IA, usuarios, personas/grupos afectados, proveedores y revisores
Riesgo	Nivel, escenarios materiales, incertidumbre, tratamiento y autoridad sobre riesgo residual
Evidencia	Evaluación, aprobaciones, monitoreo, incidentes, quejas y

Campo	Contenido mínimo
	cambios

2. Arquitectura de gestión de riesgos de IA y ciclo operativo de cuatro funciones

Las funciones Core deben reforzarse continuamente; no son cuatro casillas que se completan una sola vez.

Manual 03 memory graphic 4

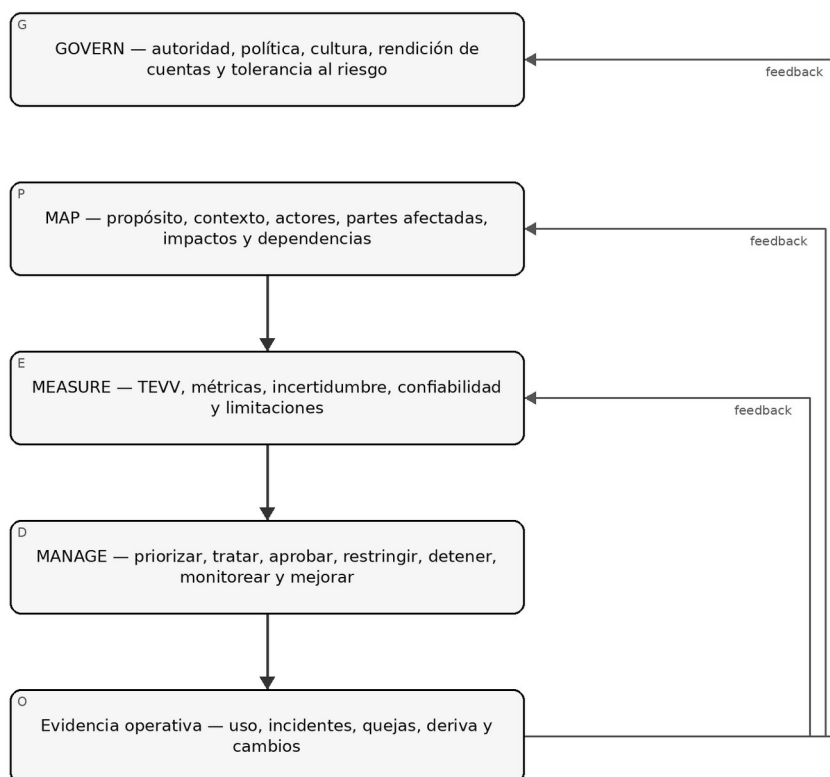


Figure 4. Chapter memory graphic

Explicación accesible: La gobernanza establece quién puede decidir y cómo se maneja el riesgo. MAP describe el contexto real y las personas o sistemas afectados. MEASURE crea evidencia mediante pruebas y otras evaluaciones. MANAGE utiliza la evidencia para tratar y aceptar o rechazar el riesgo. Los resultados operativos, incidentes, quejas y cambios retroalimentan las cuatro funciones.

2.1 La gobernanza es transversal

No aísle GOVERN como una actividad anual de comité. La gobernanza debe determinar:

- quién es responsable de cada uso de IA;
- cuándo deben participar especialistas legales, de privacidad, seguridad, safety, accesibilidad o dominio;
- qué nivel de esfuerzo de gestión de riesgos se requiere;
- quién puede aprobar el riesgo residual;
- qué evidencia se exige antes del despliegue;
- qué eventos requieren reevaluación; y
- cuándo un sistema debe restringirse, revertirse o retirarse.

2.2 Perfiles y adaptación

Una implementación práctica puede crear un perfil para un caso de uso, unidad de negocio o sector. La adaptación debe identificar:

- qué resultados de AI RMF importan más en el contexto;
- estado actual y estado objetivo deseado;
- tolerancia al riesgo y restricciones legales/contractuales;
- evidencia y métricas;
- expectativas de recursos e independencia; y
- acciones previstas con responsables y fechas.

La adaptación no debe utilizarse para ocultar riesgos conocidos de consecuencias elevadas ni para eliminar una obligación vinculante.

3. Inventario de IA, actores, propiedad y límites del ciclo de vida

Una organización no puede gobernar una IA que no puede identificar, clasificar y asignar a personas responsables.

Manual 03 memory graphic 5

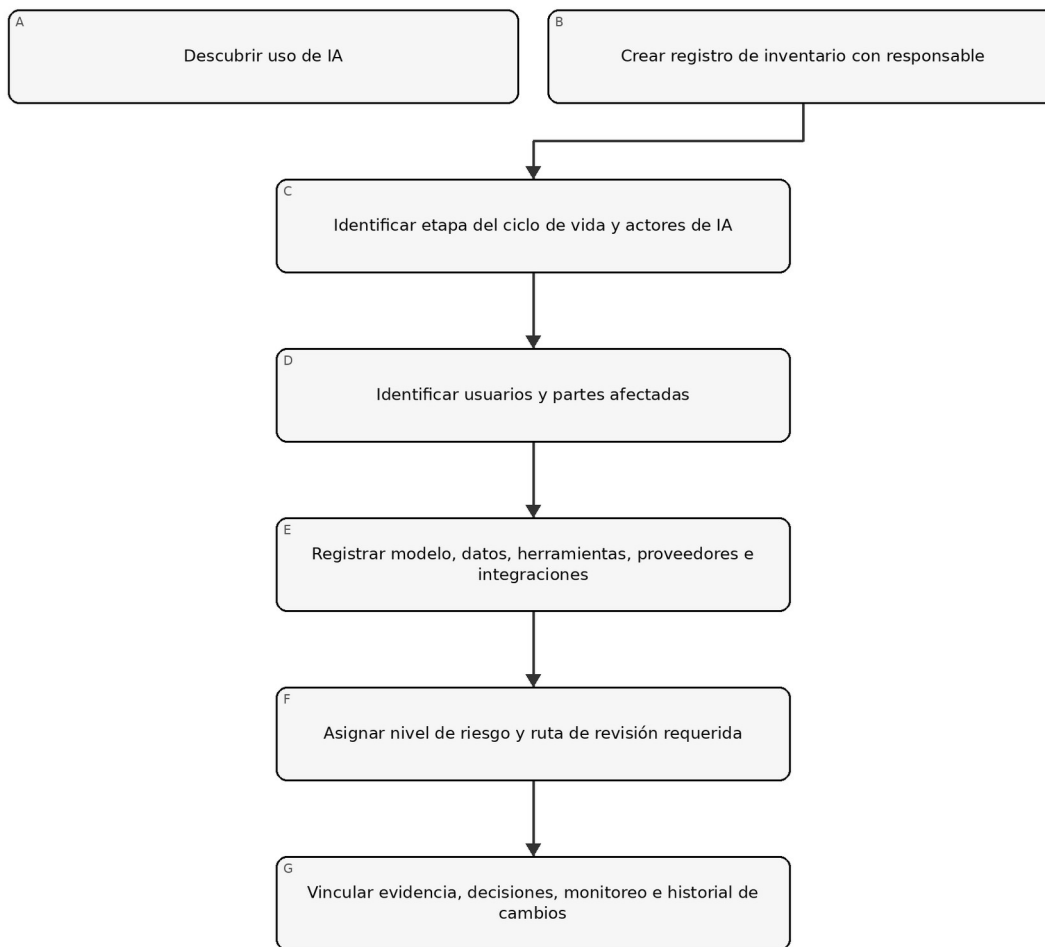


Figure 5. Chapter memory graphic

Explicación accesible: El descubrimiento crea un registro de inventario. La organización identifica después quién desarrolla, suministra, opera, utiliza, supervisa y se ve afectado por la IA; registra dependencias técnicas y de proveedores; asigna una ruta de revisión proporcional; y vincula evidencia y decisiones durante el ciclo de vida.

3.1 Fuentes de descubrimiento

Reconcilie múltiples fuentes porque el autorreporte por sí solo no detecta toda la IA en la sombra:

- registros de compras y gastos;
- inventarios de nube y SaaS;
- uso y facturación de modelos/API;
- repositorios de software y dependencias de paquetes;
- registros de identidad y acceso;
- inventarios de extensiones de endpoint/navegador;
- catálogos de datos y plataformas de integración;
- arquitectura de productos y catálogos de servicios;
- registros de riesgo de proveedores;
- entrevistas y declaraciones de empleados; y
- monitoreo de seguridad cuando sea apropiado y legal.

3.2 Actores de IA

Documente los roles según la actividad real, no según el cargo. Las actividades comunes incluyen:

- gobernanza ejecutiva y de riesgos;
- puesta en servicio del sistema y propiedad del producto;
- adquisición, preparación y administración de datos;
- desarrollo, adaptación o configuración de modelos;
- ingeniería de software e infraestructura;
- prueba, evaluación, verificación y validación;
- despliegue y operaciones;
- supervisión humana y revisión de decisiones;
- soporte al usuario, quejas y reparación;
- revisión de seguridad, privacidad, legal, compliance y safety;
- gestión de proveedores y contratos; y
- aseguramiento/auditoría independiente.

Una persona puede desempeñar varios roles en una organización pequeña, pero deben identificarse los conflictos de interés y añadirse revisiones compensatorias para riesgos materiales.

3.3 Partes afectadas

Las personas afectadas pueden no usar nunca el sistema. Considere a quienes puedan ver influido su empleo, acceso, elegibilidad, seguridad, reputación, finanzas, privacidad, expresión, aprendizaje, salud, movilidad u otros intereses por el proceso habilitado por IA.

Registre:

- usuarios directos;
- sujetos de decisiones;
- personas representadas en los datos;
- observadores y grupos afectados indirectamente;
- clientes o trabajadores aguas abajo;
- comunidades o poblaciones afectadas a escala; y
- organizaciones o sistemas públicos que dependan de los resultados.

4. Enrutamiento proporcional por riesgo y complejidad

La intensidad de recursos debe seguir las consecuencias plausibles, la incertidumbre y la complejidad, no únicamente el tamaño de la organización.

Manual 03 memory graphic 6

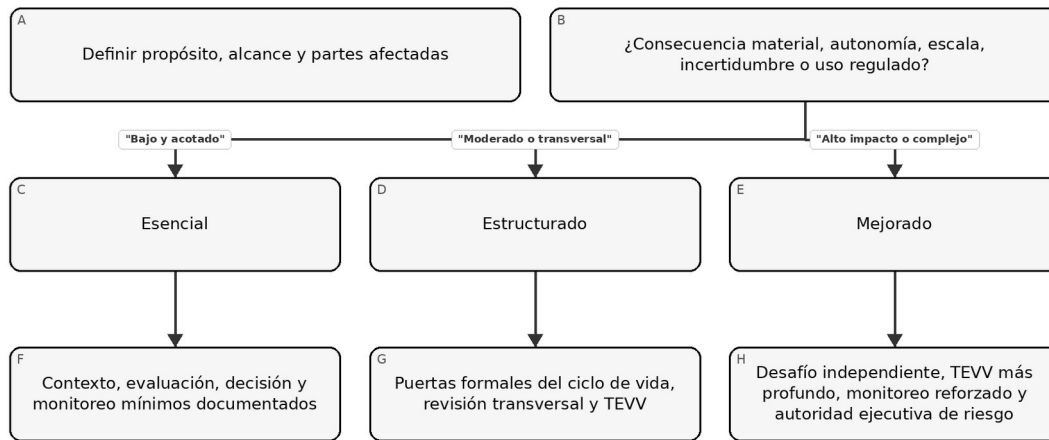


Figure 6. Chapter memory graphic

Explicación accesible: La organización comienza con el contexto y las partes afectadas y luego considera consecuencias potenciales, autonomía, escala, incertidumbre y exposición regulatoria. Los usos de bajo riesgo y alcance limitado pueden utilizar una ruta Esencial. Los usos moderados requieren una ruta Estructurada. Los usos de alto impacto o complejos requieren una ruta Mejorada con mayor independencia y supervisión.

4.1 Factores de riesgo

Considere al menos:

- severidad y reversibilidad del daño plausible;
- cantidad y vulnerabilidad de personas afectadas;
- si el uso influye en decisiones de alto impacto;
- grado de automatización o autoridad de acción;
- exposición pública y potencial de abuso;
- sensibilidad y volumen de datos;
- opacidad del modelo y control del proveedor;
- novedad e incertidumbre;
- consecuencias de ciberseguridad y safety;
- complejidad geográfica/legal;
- capacidad para monitorear y corregir resultados; y
- riesgo de concentración o dependencia de modo común.

4.2 Registro de nivel

Campo	Ejemplo de evidencia
Consecuencia inherente	Narrativa más dimensiones como safety, derechos, finanzas, seguridad u operaciones
Probabilidad/incertidumbre	Datos, juicio experto, incidentes análogos, supuestos y confianza
Exposición	Escala, frecuencia, duración, población y geografía
Autonomía	Asesoría, aprobada por humanos, ejecutada automáticamente o agéntica/con herramientas
Fortaleza del control	Controles existentes y limitaciones conocidas
Nivel/ruta	Esencial, Estructurada o Mejorada con justificación

Campo	Ejemplo de evidencia
Autoridad	Persona/comité autorizado para aprobar el nivel y el riesgo residual
Activador de revisión	Cambio, incidente, queja, deriva, actualización legal/del proveedor o revisión programada

5. Arquitectura de la función GOVERN

GOVERN hace sostenible la gestión del riesgo de IA mediante política, rendición de cuentas, cultura, participación, controles de proveedores y mecanismos de revisión.

La función GOVERN de AI RMF 1.0 agrupa sus resultados en seis temas amplios. Para implementación, trátelos como:

18. infraestructura organizacional de políticas/procesos y tolerancia al riesgo;
19. rendición de cuentas, capacitación y autoridad de decisión;
20. capacidad interdisciplinaria y roles de supervisión humano-IA;
21. cultura consciente del riesgo, documentación de impactos, pruebas e intercambio de información;
22. participación externa e interna con retroalimentación significativa; y
23. gobernanza de terceros y cadena de suministro, incluida planificación de contingencia.

Precaución de revisión: NIST ha indicado específicamente que parte de la terminología actual de AI RMF 1.0 está sujeta a revisión. Mantenga trazabilidad a nivel de identificador con la línea base controlada 1.0, pero no presente la redacción actual de categorías como texto futuro inmutable.

5.1 Jerarquía de evidencia de gobernanza

La evidencia más sólida avanza de intención a operación:

- Intención: política, estatuto, principios y tolerancia al riesgo.
- Diseño: proceso definido, roles, derechos de decisión, plantillas y controles.
- Operación: revisiones, aprobaciones, pruebas, acciones de proveedores y registros de incidentes completados.
- Eficacia: evidencia de que los controles cambian decisiones, reducen riesgo o detectan fallas.
- Mejora: causas corregidas, políticas/procesos actualizados y seguimiento verificado.

6. GOVERN: política, obligaciones legales, tolerancia al riesgo e inventario

Las políticas deben conectar prioridades de riesgo de IA con decisiones repetibles en lugar de limitarse a repetir principios generales.

6.1 Política de IA

Una política práctica debe definir:

- propósito y alcance;
- límites de uso aprobado/prohibido;
- rendición de cuentas y escalamiento;
- método de clasificación por riesgo;
- activadores de revisión legal/regulatoria/contractual;
- requisitos de datos y seguridad;
- expectativas mínimas de evaluación;
- expectativas de supervisión humana;
- controles de proveedores;
- obligaciones de monitoreo e incidentes;
- mantenimiento de registros; y
- excepciones y cumplimiento interno.

6.2 Registro de obligaciones

AI RMF es voluntario, pero los sistemas de IA pueden estar sujetos a obligaciones vinculantes. Mantenga un registro separado de obligaciones con:

Campo	Contenido mínimo
Fuente	Ley, regulación, contrato, política, estándar o requisito del cliente
Jurisdicción	País/estado/sector/relación comercial
Aplicabilidad	Sistema/uso/datos/parte/proceso afectado
Requisito	Obligación práctica expresada en lenguaje organizacional
Responsable	Función/persona accountable
Evidencia	Control, registro, prueba o aprobación
Vigilancia de cambios	Monitor de fuente y frecuencia de revisión

No etiquete una sugerencia voluntaria de NIST como ley. No declare cumplimiento legal únicamente porque exista un mapeo con un resultado de AI RMF.

6.3 Tolerancia al riesgo y esfuerzo

Defina qué decisiones pueden tomarse en cada nivel. Por ejemplo:

- aprobación del responsable para bajo riesgo dentro de criterios documentados;
- revisión transversal para riesgo moderado;
- aprobación ejecutiva/de comité para alto riesgo;
- escalamiento obligatorio para usos prohibidos o legalmente restringidos;
- desafío independiente para sistemas de altas consecuencias; y
- autoridad de parada cuando fallen controles críticos.

El esfuerzo de gestión de riesgos debe dimensionarse según la prioridad del riesgo.

6.4 Inventario como control de gobernanza

El inventario debe reconciliarse periódicamente y después de adquisiciones, despliegues o cambios materiales. Un inventario desactualizado es una falla de gobernanza porque los procesos posteriores de riesgo dependen de una población completa.

7. GOVERN: rendición de cuentas, competencia, supervisión humana y desafío efectivo

La responsabilidad debe ser suficientemente explícita para que una decisión material de IA pueda rastrearse hasta personas con autoridad y competencia.

7.1 Modelo de responsabilidades

Como mínimo identifique:

- patrocinador ejecutivo;
- responsable de negocio/sistema;
- responsable técnico/modelo;
- responsable/administrador de datos;
- revisores de riesgo/compliance/legal/privacidad/seguridad/safety según corresponda;
- rol de supervisión humana;
- responsable de proveedor;
- responsable de incidente;
- aprobador del riesgo residual; y
- rol de aseguramiento independiente cuando sea necesario.

7.2 Competencia

La competencia depende del rol. La evidencia puede incluir educación, experiencia, práctica supervisada, capacitación, evaluación y productos de trabajo revisados. La evaluación de alto riesgo requiere competencia tanto en la tecnología como en el dominio donde se producen las consecuencias.

La capacitación debe cubrir decisiones reales que las personas toman, como:

- reconocer usos no aprobados de IA;
- manejar datos restringidos;
- interpretar confianza y limitaciones de modelos;
- verificar resultados;
- reconocer sesgo de automatización;
- escalar preocupaciones de safety/seguridad/privacidad;
- responder a incidentes; y
- utilizar procedimientos de parada o contingencia.

7.3 Supervisión humana

“Human in the loop” no es suficiente por sí solo. Documente:

- qué ve la persona;
- qué se espera que verifique;
- tiempo e información disponibles;
- autoridad para discrepar o detener;
- incentivos y carga de trabajo;
- competencia;
- registro de overrides; y
- evidencia de que la intervención es eficaz.

Un revisor que acepta automáticamente la salida de IA no constituye un control significativo.

7.4 Desafío efectivo

Para riesgos materiales, utilice un revisor o grupo capaz de cuestionar supuestos y con suficiente autoridad, independencia, experiencia y acceso a evidencia para influir en la decisión. En organizaciones pequeñas, la independencia puede escalarse mediante revisión entre pares, experiencia externa o separación de la aprobación respecto de la creación.

8. GOVERN: cultura, participación, proveedores y resiliencia de terceros

La gestión del riesgo de IA depende de que la organización esté dispuesta a exponer fallas, escuchar perspectivas afectadas y controlar dependencias que no posee.

8.1 Cultura consciente del riesgo

Las prácticas útiles incluyen:

- liderazgo que recompense el escalamiento de preocupaciones materiales;
- canales protegidos de reporte;
- pre-mortems y revisión de modos de falla;
- disenso documentado en decisiones de alto riesgo;
- red teaming o desafío adversarial cuando corresponda;
- aprendizaje a partir de incidentes y casi incidentes; y
- evitar incentivos de entrega que castiguen retrasos o decisiones de parada por razones de seguridad.

8.2 Participación y retroalimentación

La participación debe ser proporcional y significativa, no performativa. Defina:

- por qué se busca retroalimentación;

- qué perspectivas afectadas o expertas se necesitan;
- cómo se selecciona y protege a los participantes;
- necesidades de accesibilidad e idioma;
- cómo se registra y resuelve la retroalimentación;
- qué cambió como consecuencia de la retroalimentación; y
- cómo se escalan las preocupaciones no resueltas.

Según el contexto, la retroalimentación puede provenir de usuarios, personas afectadas, trabajadores, expertos de dominio, soporte al cliente, quejas, procesos de apelación, bases de datos de incidentes, reguladores, investigadores u organizaciones de la sociedad civil.

8.3 Gobernanza de proveedores y terceros

Las cadenas de suministro de IA pueden incluir modelos fundacionales, API, conjuntos de datos, componentes de código abierto, herramientas de evaluación, infraestructura de nube, servicios humanos de etiquetado, filtros de safety y plataformas de orquestación.

La evidencia mínima de proveedores debe cubrir:

- producto/modelo/servicio y versión exactos;
- uso previsto y restricciones contractuales;
- manejo de datos, retención y uso para entrenamiento;
- evidencia de seguridad y privacidad;
- evidencia de desempeño/evaluación y limitaciones;
- prácticas de notificación de cambios;
- subprocesadores/dependencias;
- notificación de incidentes/vulnerabilidades;
- continuidad, portabilidad y salida; y
- distribución de responsabilidades entre proveedor y cliente.

8.4 Planificación ante fallas de terceros

Para dependencias materiales, planifique para:

- caída del modelo/servicio;
- degradación material de calidad;
- actualización silenciosa del modelo;
- incidente de seguridad del proveedor;
- pérdida de API/funcionalidad;
- cambios en términos o prácticas de datos;
- salida del proveedor o discontinuación del servicio; e
- imposibilidad de obtener evidencia necesaria para continuar aceptando el riesgo.

La contingencia puede incluir proveedores alternativos, modo degradado seguro, proceso manual, limitación de tráfico, resultados aprobados en caché, deshabilitación de funciones o parada completa según el uso.

Punto de control de la Parte 1: Los capítulos 1–8 establecen conciencia de versión, inventario, enrutamiento proporcional y la base de gobernanza. La Parte 2 continúa con MAP y el análisis del contexto afectado.

9. Arquitectura de la función MAP y registro de contexto

MAP establece suficiente contexto sociotécnico para identificar riesgos, beneficios, partes afectadas y necesidades de medición pertinentes.

El mapeo no es un cuestionario de una sola vez. Es una descripción controlada del sistema según su intención, configuración, suministro y uso real. El registro debe ser lo bastante específico para que los revisores distingan entre despliegues, poblaciones, versiones de modelo o funciones de decisión diferentes.

Manual 03 memory graphic 7

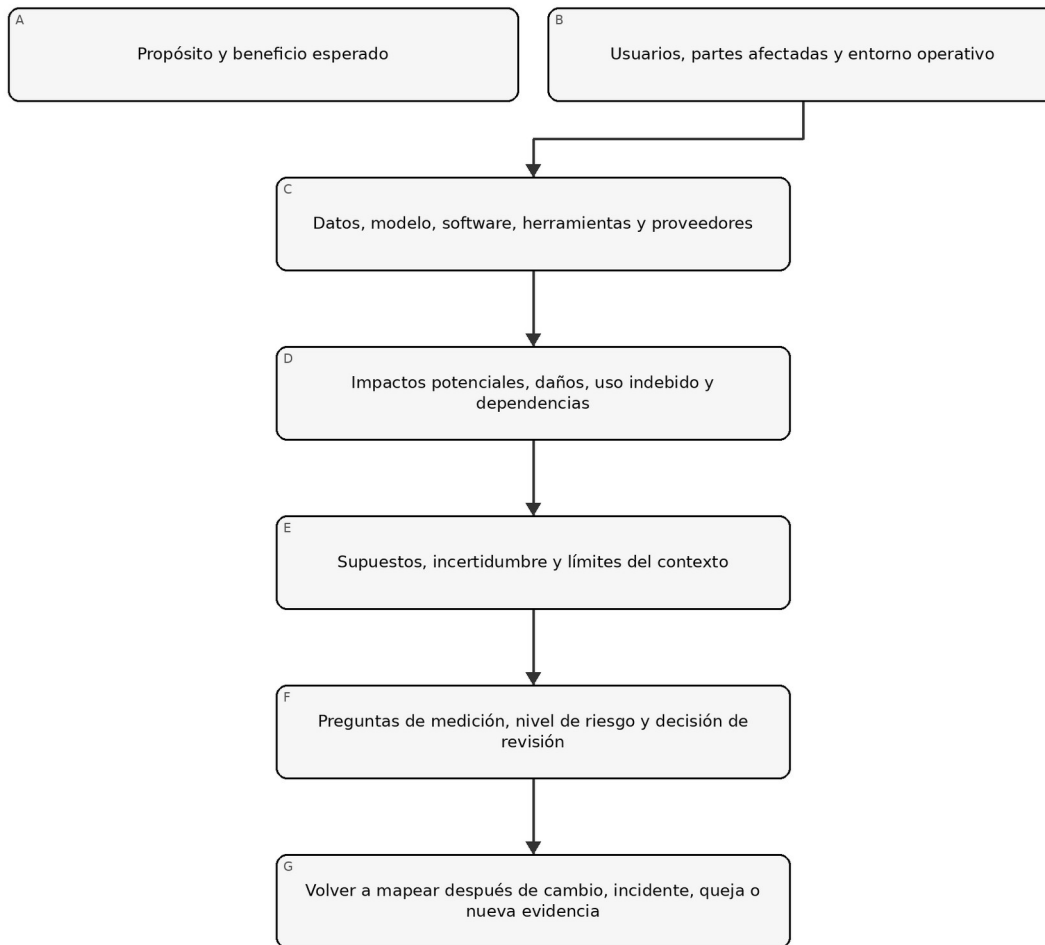


Figure 7. Chapter memory graphic

Explicación accesible: El mapeo comienza con el propósito y beneficio esperado, luego documenta usuarios y partes afectadas, dependencias técnicas y de proveedores, impactos plausibles y uso indebido, y los principales supuestos. Estos hechos determinan las preguntas de medición y el nivel de riesgo. Cambios, incidentes, quejas y nueva evidencia obligan a volver a mapear el sistema.

9.1 Registro de contexto

Mantenga un registro controlado de contexto para cada sistema o uso de IA materialmente distinto. Debe vincularse al registro de inventario e incluir:

- propósito de negocio y beneficio esperado;
- límite del sistema y etapa del ciclo de vida;
- actores de IA, responsable accountable y autoridad de decisión;
- usuarios directos, sujetos de decisiones y partes afectadas indirectamente;
- entorno operativo, geografía, frecuencia, escala y duración;
- función de decisión o contenido y grado de autonomía;
- dependencias de datos, modelos, software, herramientas e infraestructura;
- terceros y límites contractuales;
- impactos positivos y negativos plausibles;
- escenarios razonables de uso indebido y falla;

- supuestos, incertidumbres y brechas de evidencia;
- requisitos aplicables y expectativas de stakeholders;
- nivel inicial de riesgo y justificación; y
- preguntas de medición, umbrales y activadores de revisión.

9.2 Criterios de calidad del contexto

Un registro de contexto está listo para revisión cuando es:

- específico: nombra el uso, población, versión y entorno reales;
- trazable: vincula afirmaciones con evidencia, responsables y fechas;
- delimitado: declara qué queda excluido y por qué;
- plural: considera perspectivas técnicas, humanas, organizacionales y sociales cuando sea pertinente;
- cuestionable: registra supuestos y disenso en lugar de presentar certeza inexistente;
- actual: refleja la configuración desplegada o propuesta; y
- accionable: genera preguntas medibles y decisiones de gestión.

Las descripciones genéricas de producto, marketing de proveedores, eslóganes de política y resúmenes de benchmark no cumplen por sí solos este estándar.

10. Propósito previsto, alcance, actores y contexto del ciclo de vida

El riesgo no puede evaluarse sin definir qué se espera que haga la IA, dónde se utiliza y cómo interactúan las personas con ella.

10.1 Declaración de propósito previsto

Escriba el propósito en lenguaje operativo:

El sistema ayuda a [usuarios identificados] con [tarea o decisión específica] para [población/entorno definido] mediante [salida/acción]. Se espera que proporcione [beneficio medible]. No debe utilizarse para [usos prohibidos o no validados].

Evite propósitos como “mejorar eficiencia” salvo que el registro defina proceso, usuario, salida, consecuencia y métrica.

10.2 Alcance y límites

Registre:

- unidades organizacionales y procesos;
- jurisdicciones e idiomas;
- poblaciones de usuarios y afectadas;
- canales, dispositivos y entornos;
- horarios de operación y volumen esperado de transacciones;
- integraciones y decisiones downstream;
- asesoría versus acción automática;
- puntos de revisión humana;
- versiones de datos y modelos;
- estado de piloto, producción o retiro; y
- usos y entornos excluidos.

Si un mismo modelo respalda distintas decisiones, poblaciones o niveles de autonomía, cree registros de uso vinculados en lugar de ocultar la variación de riesgo dentro de una sola entrada amplia de inventario.

10.3 Contexto del ciclo de vida

Identifique las etapas actuales y previstas:

24. concepto e intake;
25. diseño o adquisición;
26. preparación de datos y desarrollo/configuración del modelo;
27. integración y evaluación previa al despliegue;

28. piloto o liberación limitada;
29. uso en producción;
30. monitoreo y cambio;
31. suspensión, rollback o remediación; y
32. retiro y disposición controlada.

La evidencia disponible cambia según la etapa. El mapeo temprano depende más de supuestos, evidencia análoga y salvaguardas planificadas. El mapeo en producción debe incorporar desempeño observado, incidentes, quejas, overrides, drift y cambios de proveedores.

10.4 Mapeo actor-tarea

Mapee personas y organizaciones a tareas reales, autoridad y evidencia. Incluya proveedores externos cuando desarrollen, configuren, evalúen, hospeden o monitoreen parte del sistema.

Actor/tarea	Actividad accountable	Evidencia requerida
Responsable de negocio	Define propósito, beneficio, proceso y riesgo residual aceptable	Caso de negocio, declaración de propósito, aprobaciones
Responsable de producto/sistema	Mantiene el registro del ciclo de vida y coordina gates	Inventario, contexto, registro de decisiones, historial de cambios
Roles de datos/modelo/ingeniería	Construyen, configuran y operan componentes técnicos	Linaje, registros de versión, diseño y evidencia de pruebas
Especialista de dominio	Prueba si el sistema funciona de forma segura en el dominio real	Revisión de escenarios, criterios de aceptación, limitaciones
Usuario de supervisión	Verifica o desafía resultados en operación	Instrucciones, competencia, evidencia de override y escalamiento
Revisores de riesgo/legal/privacidad/seguridad/safety	Aplican requisitos especializados y desafío de riesgo	Hallazgos, decisiones, condiciones y remediación
Responsable de proveedor	Controla evidencia del proveedor, contratos y cambios	Due diligence, cláusulas, avisos y plan de salida
Revisor de aseguramiento	Prueba independientemente diseño u operación cuando sea necesario	Alcance, workpapers, hallazgos y conclusión

11. Partes afectadas, beneficios, impactos y daños

La unidad de análisis relevante no es únicamente el usuario o cliente; incluye personas, grupos, organizaciones y sistemas influenciados por el proceso habilitado por IA.

11.1 Mapa de partes afectadas

Manual 03 memory graphic 8

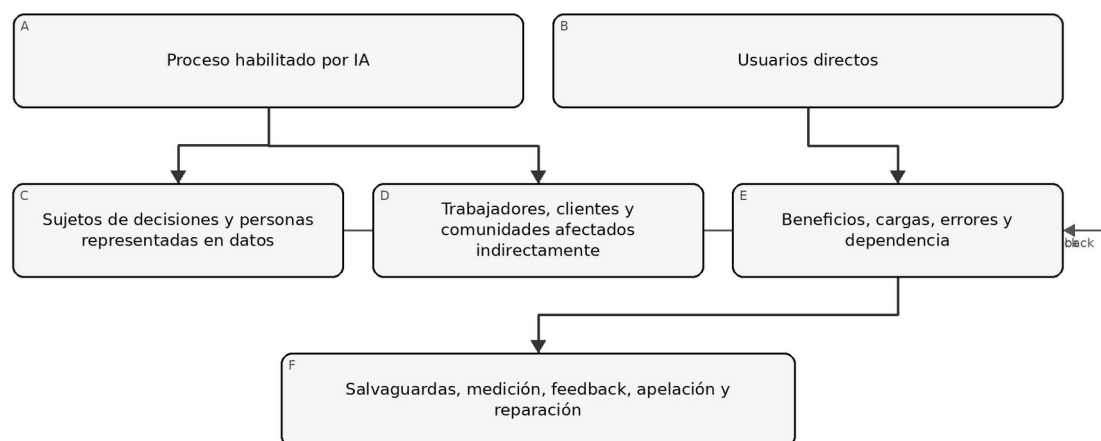


Figure 8. Chapter memory graphic

Explicación accesible: Un proceso habilitado por IA puede afectar a usuarios directos, personas que son objeto de decisiones o están representadas en datos y personas o comunidades afectadas indirectamente. El mapeo considera beneficios, cargas, errores y dependencia de cada grupo y luego determina salvaguardas, evaluación, feedback, apelación y necesidades de reparación.

11.2 Análisis de beneficios

Expresé los beneficios esperados como afirmaciones verificables. Considere:

- mejor acceso, calidad, oportunidad o consistencia;
- reducción de trabajo peligroso o repetitivo;
- mejor detección o apoyo a decisiones;
- personalización o accesibilidad;
- eficiencia de costos o recursos; y
- nuevas capacidades científicas, educativas, creativas u operativas.

Para cada beneficio material registre beneficiario, métrica, línea base, evidencia y posibles tradeoffs. Un ahorro proyectado para la organización no demuestra automáticamente un beneficio para las personas afectadas.

11.3 Escenarios de impacto y daño

Utilice declaraciones que conecten causa, evento y consecuencia:

Debido a [condición o debilidad], el sistema puede [error, uso indebido o falla] durante [contexto], causando [consecuencia] a [parte afectada]. La detección puede ser difícil debido a [limitación].

Considere:

- seguridad física o psicológica;
- derechos civiles, acceso, elegibilidad y debido proceso;
- consecuencias en empleo, educación, vivienda, crédito, seguros o salud;
- privacidad, vigilancia y autonomía;
- pérdida económica, fraude y manipulación;
- compromiso de seguridad y disrupción operativa;
- reputación, dignidad, expresión e integridad de la información;
- efectos ambientales o comunitarios cuando sean materiales;
- exclusión por diseño inaccesible o idioma; y

- efectos compuestos o acumulativos entre sistemas.

11.4 Severidad, exposición y reversibilidad

No comprima todas las dimensiones en una sola puntuación sin conservar la narrativa. Registre:

- severidad de la consecuencia plausible;
- frecuencia y duración de exposición;
- cantidad y vulnerabilidad de personas afectadas;
- reversibilidad y disponibilidad de reparación;
- capacidad de detección antes del daño;
- concentración y potencial de falla correlacionada;
- probabilidad cuando exista evidencia suficiente para estimarla; e
- incertidumbre y confianza.

11.5 Feedback y representación

Para impactos materiales, determine qué perspectiva falta. Los métodos pueden incluir entrevistas, investigación con usuarios, revisión de accesibilidad, consulta laboral, análisis de quejas, paneles de dominio, expertise de interés público, participación comunitaria o pruebas controladas con participantes representativos.

Documente cómo el feedback cambió el contexto, diseño, evaluación, restricciones o decisión. Si no puede obtenerse feedback, registre la limitación y medidas compensatorias.

12. Dependencias de datos, modelos, software, infraestructura y proveedores

El riesgo de IA surge del sistema completo y de la cadena de suministro, no únicamente del modelo.

12.1 Mapa de dependencias

Documente la cadena desplegada desde la fuente de entrada hasta la salida/acción:

- recopilación y validación de entradas;
- almacenes de datos, retrieval y transformaciones;
- modelo/proveedor y versión o endpoint exacto;
- prompts, instrucciones del sistema, fine-tuning o adaptadores;
- filtros de safety, motores de política y guardrails;
- orquestación, agentes, herramientas y permisos;
- software de aplicación e interfaz de usuario;
- controles de identidad, acceso, secretos y red;
- servicios de logging, monitoreo y evaluación;
- revisión humana y sistemas downstream; y
- dependencias de fallback, rollback y retiro.

12.2 Contexto de datos

Para cada dataset o flujo material de datos, registre:

- fuente, autoridad y propósito de recopilación;
- población y período representados;
- métodos de selección, etiquetado y transformación;
- calidad, completitud y brechas conocidas;
- datos sensibles o regulados;
- acceso, intercambio, retención y eliminación;
- procedencia y versión;
- representatividad para el contexto previsto;
- riesgo de contaminación, poisoning o leakage; y
- restricciones sobre entrenamiento, evaluación o uso secundario.

12.3 Contexto del modelo y servicio

Registre lo que la organización sabe y no sabe sobre:

- familia de modelo, versión y comportamiento ante cambios;
- información disponible sobre entrenamiento o adaptación;
- uso previsto y restringido;
- capacidades y limitaciones evaluadas;
- evidencia de seguridad, privacidad y safety;
- hosting regional y prácticas de datos;
- restricciones de disponibilidad, tasa, latencia y capacidad;
- subcontratistas y herramientas externas;
- notificación de actualizaciones y opciones de rollback; y
- portabilidad y salida.

La opacidad del proveedor es un factor de riesgo, no una prueba de seguridad o inseguridad. El cliente debe decidir si la evidencia disponible es suficiente para su propio uso y consecuencias.

12.4 Concentración y riesgo de modo común

Identifique si muchos procesos dependen del mismo modelo, dataset, nube, proveedor, método de evaluación o control de safety. Una actualización o caída de un solo proveedor puede generar fallas correlacionadas en aplicaciones que de otro modo serían separadas.

Para concentración material, defina límites, capacidad alternativa, operación degradada, fallback manual, comunicación y escalamiento ejecutivo.

13. Escenarios de uso indebido, abuso, seguridad, privacidad, safety y resiliencia

MAP incluye uso razonablemente previsible y la interacción del sistema, no solo la operación prevista.

13.1 Familias de escenarios

Considere, cuando sea pertinente:

- uso no autorizado o prohibido;
- automatización más allá de la autoridad aprobada;
- prompt injection, abuso de herramientas o permisos excesivos;
- entrada maliciosa, data poisoning o evasión;
- extracción de modelos, leakage de privacidad o salida sensible;
- integración insegura, exposición de secretos o compromiso de dependencias;
- contenido dañino, engañoso, ilegal o inseguro;
- exceso de confianza, automation bias y pérdida de habilidades humanas;
- salida inexacta, fabricada o inadecuada para el contexto;
- fallas por subgrupos o accesibilidad;
- denegación de servicio, agotamiento de capacidad o caída de proveedor;
- falla de monitoreo/logging;
- falla de rollback o parada; y
- abuso a escala o uso indebido coordinado.

13.2 Workpaper de casos de uso indebido

Campo	Pregunta
Actor	¿Quién podría utilizar indebidamente la capacidad, intencional o accidentalmente?
Acceso	¿Qué acceso de identidad, datos, prompt, herramienta o integración está disponible?
Ruta	¿Cómo podrían eludirse o manipularse los controles normales?
Consecuencia	¿Qué podría ocurrir a personas, sistemas u organización?

Campo	Pregunta
Evidencia	¿Qué incidentes, pruebas, threat intelligence o casos análogos respaldan el escenario?
Prevención	¿Qué controles de autorización, diseño o proceso reducen la oportunidad?
Detección	¿Qué señal identifica intento o uso indebido exitoso?
Respuesta	¿Quién puede contener, revocar, hacer rollback, notificar y recuperar?
Riesgo residual	¿Qué queda y quién puede aceptarlo?

13.3 IA agéntica y con uso de herramientas

Cuando la IA pueda llamar herramientas o ejecutar transacciones, mapee:

- herramientas permitidas y bloqueadas;
- límites de identidad y credenciales;
- permisos de lectura, escritura, aprobación y ejecución;
- límites de transacción, tiempo y recursos;
- requisitos de confirmación;
- aislamiento del entorno;
- memoria y contexto retenido;
- límites de confianza de entrada/salida;
- monitoreo y trazas completas de acciones;
- revisión humana compensatoria; y
- parada de emergencia y revocación deterministas.

14. Supuestos, incertidumbre, validez del contexto y activadores de cambio

Un registro de riesgo que oculta incertidumbre genera falsa confianza y debilita decisiones posteriores.

14.1 Registro de supuestos

Para cada supuesto material, registre:

- declaración;
- responsable;
- fundamento o evidencia;
- confianza;
- consecuencia si resulta falso;
- método de validación y fecha objetivo;
- controles vinculados; y
- evento que lo invalida.

Ejemplos incluyen competencia esperada del usuario, comportamiento estable del proveedor, datos de evaluación representativos, tiempo suficiente para revisión humana, logging confiable o escala limitada de despliegue.

14.2 Tipos de incertidumbre

Distinga incertidumbre causada por:

- evidencia insuficiente o de baja calidad;
- poblaciones o entornos cambiantes;
- no determinismo del modelo;
- opacidad del proveedor;
- modos de falla raros o emergentes;
- limitaciones de medición;
- desacuerdo entre expertos o partes afectadas;

- comportamiento adversarial desconocido; e
- interpretación legal o contractual incompleta.

La incertidumbre debe influir en la profundidad de evaluación, límites de despliegue, monitoreo, fallback y autoridad sobre riesgo residual.

14.3 Declaración de validez de contexto

Todo resultado material de evaluación debe indicar el contexto en el que se considera aplicable. Como mínimo vincule el resultado con:

- modelo/servicio y versión;
- prompts, configuración y herramientas;
- datos/población y período;
- entorno y workflow;
- usuario y modelo de supervisión;
- condiciones medidas; y
- exclusiones conocidas.

14.4 Activadores de cambio

Manual 03 memory graphic 9

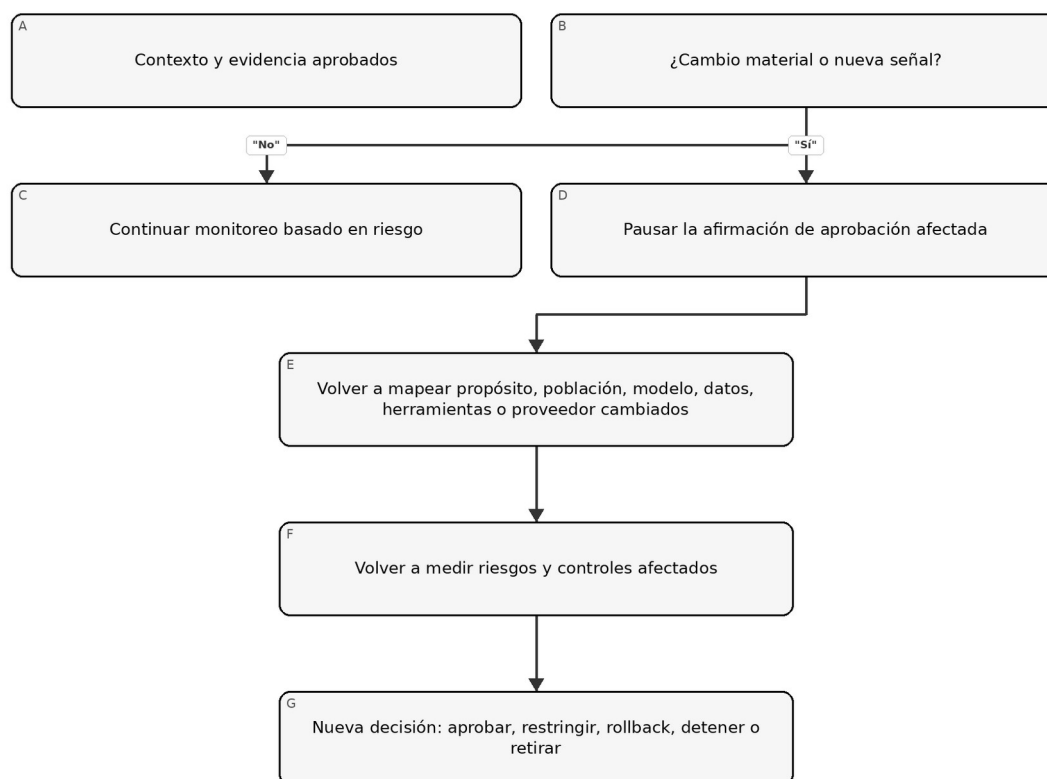


Figure 9. Chapter memory graphic

Explicación accesible: Un sistema aprobado permanece bajo monitoreo. Un cambio material o nueva señal pausa la confianza en la evidencia de aprobación afectada. La organización vuelve a mapear lo que cambió, reevalúa riesgos y controles afectados y registra una nueva decisión de gestión.

Active reevaluación después de cambios de propósito, población, geografía, modelo, datos, prompts, herramientas, autonomía, proveedor, interfaz, decisión downstream, supervisión humana o requisito aplicable. Incidentes, quejas, drift, hallazgos de seguridad y controles fallidos también son activadores.

15. Requisitos, estándares, expectativas de stakeholders y criterios de riesgo

MAP debe identificar las restricciones de decisión que MEASURE y MANAGE deberán aplicar.

15.1 Fuentes de requisitos

Las fuentes pertinentes pueden incluir:

- leyes y regulaciones;
- contratos y compromisos con clientes;
- política organizacional y apetito de riesgo;
- reglas sectoriales y deberes profesionales;
- estándares de seguridad, privacidad, safety, accesibilidad y calidad;
- restricciones de propiedad intelectual y uso de datos;
- afirmaciones de producto e instrucciones de usuario;
- negociación colectiva o compromisos laborales; y
- expectativas identificadas mediante participación de partes afectadas.

Mantenga los requisitos vinculantes separados de la orientación voluntaria del marco. Confirme interpretaciones legales mediante el proceso jurídico autorizado de la organización.

15.2 Criterios de aceptación

Traduzca el contexto en criterios que puedan respaldar una decisión. Los criterios deben indicar:

- medida o condición;
- umbral o estándar cualitativo;
- población/escenario pertinente;
- fuente de evidencia;
- responsable y revisor;
- efecto bloqueante versus asesor;
- autoridad de excepción; y
- vencimiento o activador de reevaluación.

Evite seleccionar umbrales únicamente porque el sistema ya los cumple. Documente la justificación basada en consecuencias.

15.3 Objetivos en conflicto y tradeoffs

Las características de confiabilidad pueden interactuar. Mejorar privacidad puede reducir detalle disponible para monitoreo; aumentar explicabilidad puede exponer información sensible de seguridad; un filtrado más fuerte puede afectar utilidad o accesibilidad. Registre el tradeoff, partes afectadas, alternativas, evidencia, autoridad de decisión y riesgo residual.

16. Paquete de evidencia MAP, revisión y entrega a MEASURE

MAP está suficientemente completo para el siguiente gate cuando los revisores pueden identificar qué debe evaluarse y por qué.

16.1 Paquete MAP mínimo

33. inventario actual y registro de responsabilidad;
34. declaración de propósito previsto y usos prohibidos;
35. límite del sistema, ciclo de vida y despliegue;

36. mapa de actor-tarea y responsabilidades;
37. análisis de partes afectadas y beneficio-impacto;
38. mapa de dependencias de datos/modelo/software/infraestructura/proveedor;
39. escenarios de uso indebido, falla, seguridad, privacidad, safety y resiliencia;
40. registro de requisitos y criterios de aceptación;
41. registro de supuestos, incertidumbre y brechas de evidencia;
42. nivel inicial de riesgo y justificación de ruta de revisión;
43. preguntas de medición y evidencia prevista; y
44. hallazgos de revisores, disenso no resuelto y condiciones de aprobación.

16.2 Preguntas de revisión MAP

- ¿El registro describe el sistema/uso real en lugar de un producto genérico?
- ¿Las partes afectadas van más allá de usuarios directos cuando corresponde?
- ¿Se consideran conjuntamente impactos positivos, daños e incertidumbre?
- ¿Las dependencias de sistema y proveedores son específicas de versión?
- ¿Se incluyen uso indebido y fallas razonablemente previsibles?
- ¿Los requisitos y criterios de aceptación corresponden al contexto?
- ¿Las brechas de evidencia son visibles?
- ¿El nivel de riesgo coincide con consecuencia e incertidumbre?
- ¿Se preservan disenso material y preguntas abiertas?
- ¿Los activadores para volver a mapear son explícitos?

16.3 Entrega a MEASURE

Convierta cada escenario, afirmación o requisito material en una o más preguntas de evaluación. Para cada pregunta identifique:

- la decisión que respalda;
- población y contexto pertinentes;
- método y fuente de evidencia;
- métrica o rúbrica cualitativa;
- umbral y expectativa de confianza;
- independencia y competencia necesarias;
- limitaciones e incertidumbre que deben reportarse; y
- resultado que exigiría restricción, remediación o parada.

Punto de control de la Parte 2: Los capítulos 9–16 establecen el contexto operativo y las preguntas de evidencia. La Parte 3 construye el programa MEASURE que prueba afirmaciones, riesgos y controles frente a ese contexto.

17. Arquitectura de la función MEASURE y gobierno de TEVV

MEASURE produce evidencia relevante para decisiones sobre el comportamiento del sistema, el riesgo, las características de confiabilidad, los controles y la incertidumbre dentro del contexto establecido en MAP.

Las pruebas, la evaluación, la verificación y la validación están relacionadas, pero no son intercambiables:

- Pruebas: ejecutan casos o condiciones definidos y registran los resultados observados.
- Evaluación: juzga la evidencia frente a criterios y necesidades de decisión.
- Verificación: determina si se cumplieron requisitos especificados o expectativas de diseño.
- Validación: determina si el sistema es adecuado para el propósito y contexto reales previstos.

Manual 03 memory graphic 10

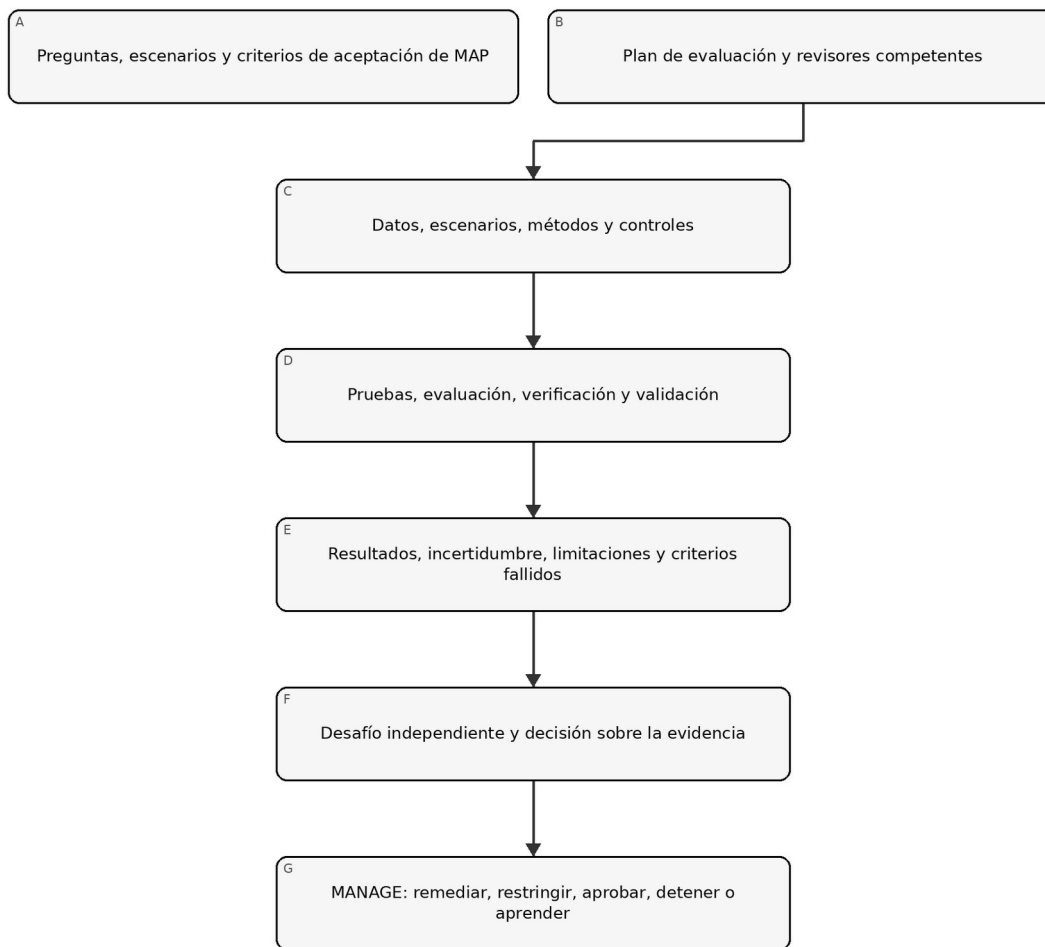


Figure 10. Chapter memory graphic

Explicación accesible: MAP proporciona preguntas, escenarios y criterios de aceptación. El plan de evaluación selecciona revisores competentes, datos, escenarios y métodos. TEVV produce resultados con incertidumbre y limitaciones. Los revisores desafían la evidencia antes de que la administración la utilice para remediar, restringir, aprobar, detener o mejorar el sistema.

17.1 Principios de medición

La evaluación debe estar:

- vinculada con una decisión específica;
- representada por el contexto previsto y razonablemente previsible;
- vinculada a una versión y ser reproducible cuando sea factible;
- proporcionada a la consecuencia y la incertidumbre;
- respaldada por varias disciplinas para riesgos sociotécnicos;
- suficientemente independiente para proporcionar desafío efectivo;
- explícita sobre fallos y evidencia faltante;
- protegida contra manipulación de métricas y filtración de benchmarks; y
- repetida después de un cambio material o de una degradación de la evidencia.

17.2 Inventario de medición

Mantenga un registro de preguntas de evaluación. Cada registro debe identificar:

Campo	Contenido mínimo
Pregunta	Afirmación, requisito, escenario o control que se evalúa
Decisión	Aprobación, restricción, diseño de control o decisión de monitoreo respaldada
Contexto	Población, ambiente, flujo de trabajo, usuario y versión
Método	Prueba, análisis, revisión, simulación, experimento, auditoría o monitoreo
Criterios	Umbral, rúbrica, comparador y condición bloqueante
Evidencia	Dataset, conjunto de escenarios, logs, revisión experta u otra fuente
Revisor	Ejecutor, persona que desafía y competencia requerida
Momento	Previo a liberación, periódico, continuo, activado por evento o retiro
Limitación	Incertidumbre, exclusión o riesgo de transferencia conocido
Resultado	Aprobado, condicional, fallido, inconcluso o no probado

17.3 Gobierno de la medición

Defina quién puede aprobar métodos, umbrales y excepciones. Un equipo que construyó el sistema puede realizar pruebas, pero los riesgos materiales pueden requerir validación o desafío separado. La independencia puede obtenerse mediante separación organizacional, un par calificado, un especialista externo, un revisor rotativo o una función de auditoría de manera proporcional al riesgo.

18. Plan de evaluación, métodos, datos, umbrales e independencia

Un resultado solo es tan útil como la pregunta, el método, la evidencia y la regla de decisión que lo sustentan.

18.1 Contenido del plan de evaluación

El plan debe registrar:

45. sistema/uso, versión y contexto;
46. afirmaciones, escenarios y requisitos derivados de MAP;
47. preguntas de evaluación y responsables de decisión;
48. métodos y justificación;
49. datos de prueba, casos, escenarios y muestreo;
50. poblaciones y subgrupos pertinentes;
51. línea base, comparador y criterios de aceptación;
52. ambiente de ejecución y controles;
53. roles, competencia e independencia de los revisores;
54. protecciones de seguridad, privacidad y safety para la propia evaluación;
55. método de análisis de resultados e incertidumbre;
56. fallos bloqueantes y escalamiento;
57. requisitos de reproducibilidad y retención de evidencia; y
58. activadores de repetición de prueba y cambio.

18.2 Selección de métodos

Use múltiples métodos cuando uno solo no pueda capturar el riesgo:

- pruebas cuantitativas de desempeño;
- revisión cualitativa basada en rúbricas;

- pruebas de escenarios y modos de falla;
- simulación o experimento controlado;
- evaluación de usabilidad y factores humanos;
- análisis de subgrupos y accesibilidad;
- evaluación de privacidad y seguridad;
- pruebas adversarias o red-team;
- revisión de código, arquitectura, datos y procesos;
- validación de evidencia de proveedores;
- análisis de logs operativos, incidentes y quejas; y
- revisión por expertos o partes afectadas.

18.3 Datos de evaluación

Verifique que los datos de evaluación sean adecuados para la afirmación. Registre fuente, autoridad, población, período, recopilación, preprocesamiento, etiquetado, exclusiones, calidad, contenido sensible, versión y separación respecto del entrenamiento o ajuste cuando corresponda.

Los datos de prueba pueden crear riesgos de privacidad, seguridad, safety o propiedad intelectual. Aplique controles de acceso, minimización, aislamiento, retención y eliminación.

18.4 Umbrales y rúbricas

Defina umbrales antes de examinar los resultados finales cuando sea práctico. Explique:

- por qué el umbral es aceptable para la consecuencia;
- si se aplica a promedios, colas, subgrupos o eventos individuales;
- expectativa de confianza o incertidumbre;
- excepciones permitidas;
- condiciones bloqueantes; y
- quién puede cambiarlo.

Los promedios pueden ocultar fallos graves de subgrupos o eventos raros. Incluya análisis de distribución, peor caso o escenarios específicos cuando las consecuencias lo justifiquen.

18.5 Integridad de la evaluación

Proteja la evaluación contra:

- seleccionar solo casos favorables;
- cambiar criterios después de conocer los resultados;
- contaminación o memorización del benchmark;
- ajustar al conjunto de prueba sin confirmación independiente;
- excluir fallos sin una justificación documentada;
- desajuste de versión entre los sistemas probado y desplegado;
- conflictos de interés de los revisores; y
- reportar únicamente puntuaciones agregadas sin limitaciones.

19. Validez, confiabilidad y evaluación del desempeño de la tarea

La evidencia de desempeño debe reflejar la tarea real, no solo un benchmark conveniente.

19.1 Descomposición de afirmaciones

Descomponga afirmaciones generales en propiedades observables. “Preciso” podría incluir:

- clasificación o predicción correcta;
- completitud de la información requerida;
- calibración o comportamiento de confianza;
- consistencia entre ejecuciones repetidas;
- estabilidad ante variaciones esperadas;
- oportunidad y latencia;

- abstención apropiada o señalización de incertidumbre; y
- comportamiento aceptable de errores entre poblaciones pertinentes.

19.2 Validez

Pregunte si la evaluación realmente respalda la inferencia prevista:

- ¿La prueba representa la tarea y la población?
- ¿La referencia o ground truth es creíble?
- ¿Las etiquetas y rúbricas son suficientemente confiables?
- ¿Los principales factores de confusión están controlados o reportados?
- ¿El desempeño offline se transfiere al flujo de trabajo?
- ¿La interacción humana cambia el resultado?
- ¿Se incluyen las acciones downstream?

19.3 Confiabilidad

Evalúe la consistencia entre:

- ejecuciones repetidas;
- semillas o ejecuciones no deterministas;
- tiempo y carga operativa;
- dispositivos, regiones o ambientes;
- variación pertinente de entradas;
- revisores o anotadores; y
- versiones de modelo/proveedor.

Para sistemas generativos, use múltiples muestras y revisión estructurada en lugar de presentar una salida favorable como evidencia.

19.4 Análisis de errores

No se detenga en una sola puntuación. Caracterice:

- tipos de error y severidad;
- consecuencias de falsos positivos y falsos negativos;
- comportamiento de cola y eventos raros;
- variación entre subgrupos e intersecciones cuando corresponda;
- comportamiento de abstención y escalamiento;
- detectabilidad de errores por los usuarios;
- amplificación downstream; y
- condiciones operativas vinculadas con fallos.

19.5 Evaluación comparativa

Compare con el proceso actual, un sistema más simple, desempeño humano calificado u otra línea base razonable. Registre diferencias de costo, tiempo, acceso, calidad, safety y carga. La pregunta relevante suele ser si el proceso habilitado por IA mejora el sistema general de decisión, no si el modelo supera una sola métrica aislada.

20. Evaluación de safety, ciberseguridad, robustez y resiliencia

Los sistemas de IA materiales requieren evidencia sobre su comportamiento bajo estrés, ataque, falla y recuperación.

20.1 Modelo de evaluación

Manual 03 memory graphic 11

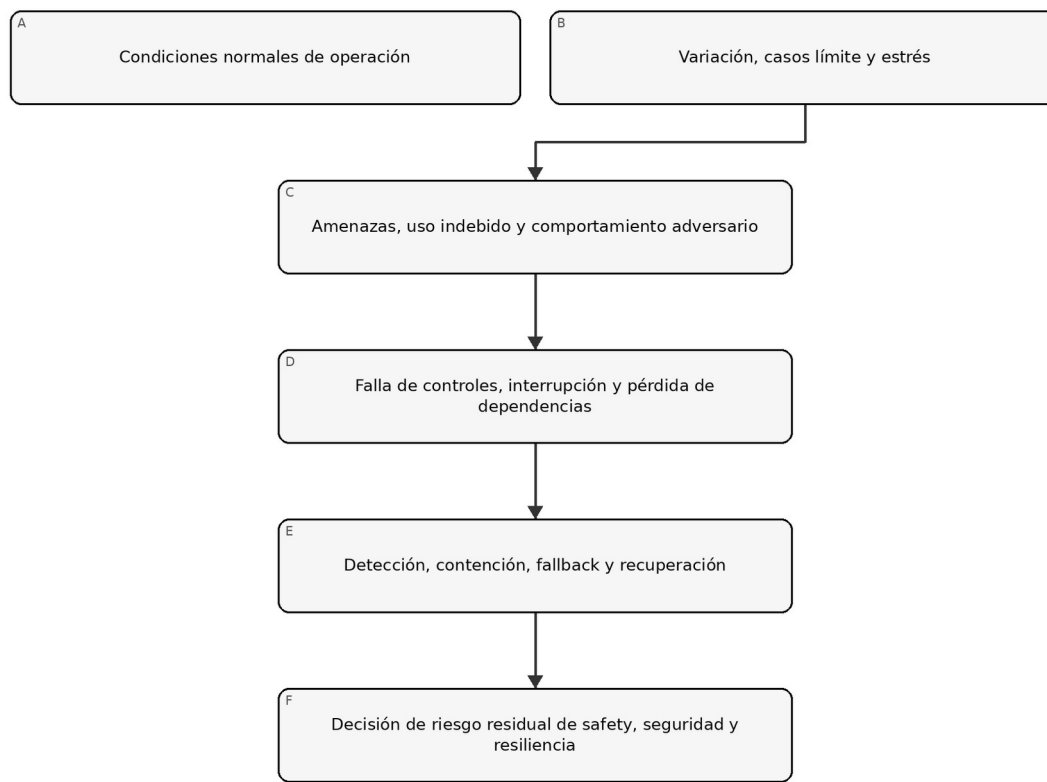


Figure 11. Chapter memory graphic

Explicación accesible: La evaluación comienza con la operación normal, se amplía a casos límite y estrés y después prueba amenazas y uso indebido. También examina fallas de controles o dependencias y si la organización puede detectar, contener, usar alternativas y recuperarse antes de decidir qué riesgo residual permanece.

20.2 Evaluación de safety

Según corresponda, evalúe:

- peligros y acciones inseguras;
- uso y uso indebido previsibles;
- interacción insegura con personas o sistemas físicos;
- detección de fallas y estado seguro;
- tiempo de intervención humana;
- parada de emergencia y alternativa manual;
- consecuencias en cascada; y
- validación de recuperación.

Utilice experiencia especializada del dominio de safety cuando las consecuencias excedan una falla ordinaria de software.

20.3 Evaluación de ciberseguridad

Incluya el sistema de IA completo. Considere:

- envenenamiento de datos y entradas maliciosas;

- evasión y ejemplos adversarios;
- prompt injection e indirect prompt injection;
- agencia excesiva y uso indebido de herramientas;
- extracción de modelo, prompts, datos o secretos;
- manejo inseguro de salidas;
- debilidades de control de acceso e identidad;
- compromiso de dependencias y cadena de suministro de software;
- denegación de servicio y agotamiento de recursos;
- evasión de logging o monitoreo; y
- cambios no autorizados de modelo/configuración.

Use ambientes controlados y autorización explícita para pruebas adversarias. No exponga innecesariamente datos sensibles reales ni sistemas de producción.

20.4 Robustez

Pruebe el comportamiento ante variación esperada y perturbaciones plausibles, incluidas entradas ruidosas, incompletas, ambiguas, fuera de distribución, multilingües o manipuladas intencionalmente cuando corresponda. La robustez depende del contexto; resistir una prueba no demuestra robustez general.

20.5 Resiliencia y recuperación

Ejercite:

- caída del proveedor o modelo;
- degradación de latencia o capacidad;
- falla de filtros de safety;
- datos corruptos o no disponibles;
- pérdida de logging o monitoreo;
- revocación de credenciales;
- rollback a una versión conocida;
- operación degradada o manual;
- comunicación de incidentes; y
- validación de restauración.

Registre tiempo de recuperación, punto de recuperación, carga de trabajo manual, reconciliación de datos y limitaciones residuales.

21. Evidencia de rendición de cuentas, transparencia, explicabilidad e interpretabilidad

La información es útil solo cuando permite que la persona prevista comprenda, actúe, cuestione o busque reparación.

21.1 Transparencia específica para la audiencia

Identifique lo que necesita cada audiencia:

Audiencia	Necesidad típica
Usuario/operador	Propósito, uso correcto, límites, verificación, escalamiento e instrucciones de parada
Persona afectada	Participación de IA, consecuencia relevante, explicación accesible y ruta de corrección/apelación
Propietario/administración	Riesgo, evidencia, fallos, riesgo residual, incidentes y condiciones de decisión
Equipo técnico	Versiones, datos, métodos, limitaciones, monitoreo y detalles de cambio
Revisor/auditor	Evidencia trazable, aprobaciones, criterios, papeles de trabajo y operación de controles
Regulador/cliente	Información requerida por la autoridad aplicable o contrato,

Audiencia	Necesidad típica
	sujeta a revisión legal

21.2 Explicabilidad e interpretabilidad

Evalúe si el método de explicación es adecuado para el modelo, decisión, audiencia y consecuencia. Pruebe:

- fidelidad al comportamiento real del sistema;
- estabilidad y consistencia;
- completitud para la necesidad de decisión;
- comprensibilidad y accesibilidad;
- capacidad de actuar a partir de la explicación;
- resistencia a una presentación engañosa; y
- compensaciones de seguridad/privacidad.

Una explicación que parece plausible pero no refleja el sistema es peor que una limitación declarada con honestidad.

21.3 Trazabilidad y rendición de cuentas

Confirme que la organización pueda reconstruir:

- qué sistema/versión actuó;
- entrada y contexto pertinentes, sujetos a límites de privacidad;
- salida o acción;
- revisión humana o anulación;
- política aplicable y estado de controles;
- autoridad de decisión;
- vínculo con incidente o queja; y
- corrección o cambio posterior.

22. Evaluación de privacidad y sesgo perjudicial

Los riesgos relacionados con privacidad y equidad requieren contexto, análisis de partes afectadas y más de una métrica agregada.

22.1 Evaluación de privacidad

Evalúe el ciclo de vida completo de los datos:

- autoridad y propósito;
- minimización y necesidad;
- aviso y elección significativa cuando corresponda;
- tratamiento de datos sensibles;
- exposición en entrenamiento, retrieval, prompts y salidas;
- riesgo de inferencia o reidentificación;
- retención y eliminación;
- acceso, intercambio y subprocesadores;
- privacidad de monitoreo/logging; y
- procesos de corrección, acceso u otros derechos aplicables.

Las pruebas técnicas pueden incluir análisis de leakage, memorización, extracción o inferencia según corresponda, pero deben combinarse con evidencia de gobierno y procesos.

22.2 Evaluación de sesgo perjudicial

Comience por los daños mapeados y los grupos afectados. Determine:

- qué resultados o errores importan;
- qué grupos e intersecciones requieren análisis;
- qué comparación es significativa;
- si los datos respaldan la inferencia;
- si la métrica refleja el proceso real de decisión;

- si la revisión humana mitiga o amplifica el efecto;
- qué umbral o juicio cualitativo se aplica; y
- qué remedio existe.

Ninguna métrica de equidad es universalmente correcta. Registre la justificación, compensaciones, revisión legal cuando se requiera, limitaciones y riesgo residual.

22.3 Evidencia de proceso y resultado

Revise ambos tipos:

- evidencia de proceso: participación, gobierno de datos, decisiones de diseño, revisión, documentación y manejo de quejas; y
- evidencia de resultado: patrones de desempeño, error, asignación, carga o impacto en el contexto real.

22.4 Accesibilidad e idioma

Evalúe si interfaces, avisos, explicaciones, soporte y rutas de apelación funcionan para necesidades pertinentes de discapacidad, alfabetización, idioma y acceso tecnológico. Los defectos de accesibilidad pueden crear exclusión sistemática incluso cuando el desempeño del modelo parezca aceptable.

23. Factores humanos, supervisión y evaluación de partes afectadas

El desempeño del equipo humano-IA puede diferir materialmente del desempeño del modelo medido por separado.

23.1 Prueba de eficacia de la supervisión

Evalúe si la persona responsable de supervisar:

- reconoce cuándo participa la IA;
- entiende el propósito y las limitaciones;
- dispone de suficiente información y tiempo;
- puede identificar errores importantes;
- puede disentir sin penalización;
- puede corregir, anular o detener;
- utiliza correctamente el escalamiento y fallback; y
- deja un registro auditable.

Mida sesgo de automatización, complacencia, carga de trabajo, fatiga de alertas, degradación de habilidades y diferencias entre niveles de experiencia.

23.2 Evaluación del flujo humano-IA

Compare, al menos cuando sea material:

- línea base solo humana;
- resultado solo de IA para comprensión diagnóstica;
- persona con asistencia de IA;
- diferentes diseños de interfaz o explicación; y
- operación degradada o fallback.

El modelo operativo aprobado debe ser el que realmente se evaluó.

23.3 Evaluación de partes afectadas

Los métodos pueden incluir pruebas de usabilidad accesibles, entrevistas, análisis de quejas, pilotos controlados, revisión del recorrido, evaluación participativa o paneles de expertos del dominio. Proteja a participantes e información sensible y evite trasladar por completo a las personas afectadas la carga de demostrar el daño.

23.4 Apelaciones, corrección y reparación

Pruebe si una persona puede:

- reconocer una decisión o salida pertinente;
- obtener información comprensible;
- presentar una corrección o impugnación;
- acceder a una persona competente;
- recibir atención oportuna;
- evitar propagación repetida cuando corresponda; y
- obtener el remedio autorizado por política o ley.

24. Incertidumbre, limitaciones, revisión de resultados y paquete de evidencia MEASURE

Los responsables de decisión necesitan una descripción fiel de lo que la evidencia respalda, lo que no respalda y qué tan rápido puede quedar obsoleta.

24.1 Registro de resultados

Para cada evaluación material, conserve:

- ID de evaluación y pregunta MAP vinculada;
- versiones del sistema, modelo, datos, prompt/configuración y software;
- método, ambiente y fecha de ejecución;
- dataset/conjunto de escenarios y muestreo;
- criterios y umbrales predefinidos;
- ejecutor, revisor y competencia;
- resultados detallados y resumidos;
- fallos, exclusiones y anomalías;
- incertidumbre y confianza;
- limitaciones y condiciones de transferencia;
- manejo de seguridad/privacidad;
- hallazgos y remediación;
- resultados de repetición de prueba; y
- disposición de la administración.

24.2 Declaración de incertidumbre

Indique:

59. qué se conoce con respaldo razonable;
60. qué permanece incierto;
61. por qué existe la incertidumbre;
62. cómo la incertidumbre podría afectar a personas o decisiones;
63. controles o límites de despliegue utilizados debido a ella;
64. monitoreo o investigación planificados; y
65. quién aceptó la incertidumbre restante y hasta cuándo.

24.3 Clasificación de resultados

- Aprobado: la evidencia cumple los criterios definidos en el contexto probado.
- Condicional: los criterios solo se cumplen bajo restricciones documentadas o controles compensatorios.
- Fallido: uno o más criterios bloqueantes no se cumplen.
- Inconcluso: la evidencia es insuficiente o inconsistente para la decisión.
- No probado: la pregunta permanece abierta y no puede representarse como satisfecha.

Falle de forma cerrada cuando un resultado obligatorio haya fallado, sea inconcluso, falte, no corresponda a la versión, haya vencido o haya sido invalidado por un cambio material.

24.4 Revisión de evidencia

Manual 03 memory graphic 12

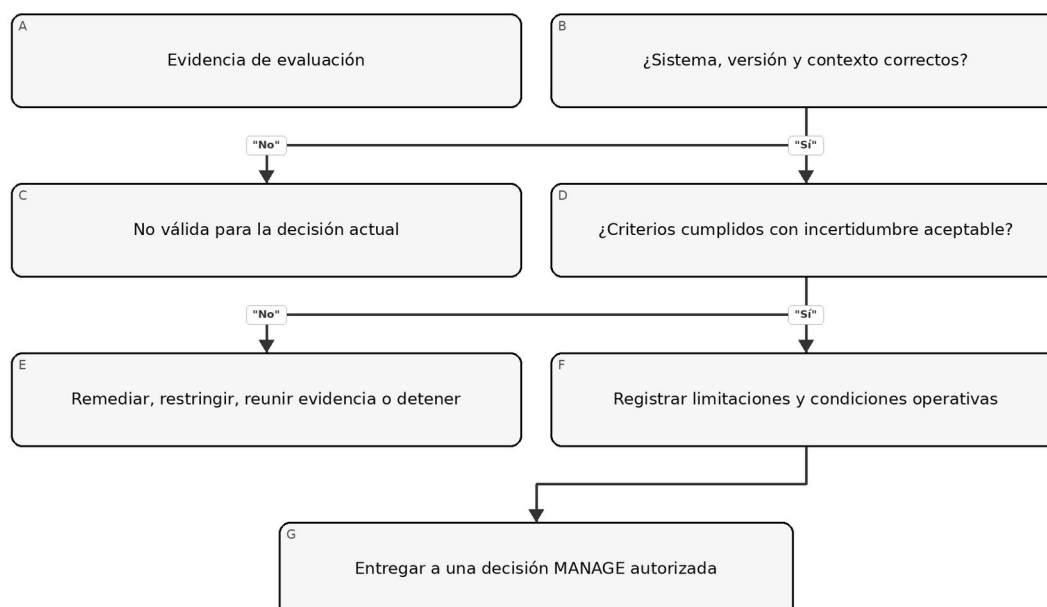


Figure 12. Chapter memory graphic

Explicación accesible: La revisión primero confirma que la evidencia corresponda al sistema, versión y contexto correctos. Si no, es inválida. Si los criterios o la incertidumbre son inaceptables, la organización remedia, restringe, reúne más evidencia o detiene. La evidencia aceptable se entrega a una decisión de administración autorizada conservando limitaciones y condiciones.

24.5 Paquete mínimo de MEASURE

66. plan de evaluación aprobado;
67. matriz de preguntas a métodos;
68. datasets controlados y manifiestos de escenarios;
69. registro de ambiente y versión;
70. resultados ejecutados y análisis;
71. evidencia de características de confiabilidad pertinentes al contexto;
72. evaluación humana/de partes afectadas cuando sea necesaria;
73. elementos fallidos, inconclusos y no probados;
74. declaración de incertidumbre y limitaciones;
75. desafío del revisor, hallazgos y remediación;
76. evidencia de repetición de pruebas; y
77. resumen listo para decisión vinculado con papeles de trabajo detallados.

Punto de control Parte 3: Los capítulos 17–24 crean evidencia sin sobreestimarla. La Parte 4 utiliza esa evidencia para priorizar, tratar, decidir, monitorear, responder y mejorar mediante MANAGE.

25. Arquitectura de la función MANAGE y priorización del riesgo

MANAGE convierte el contexto mapeado y la evidencia medida en tratamiento priorizado, decisiones responsables, controles operativos y mejora.

Manual 03 memory graphic 13

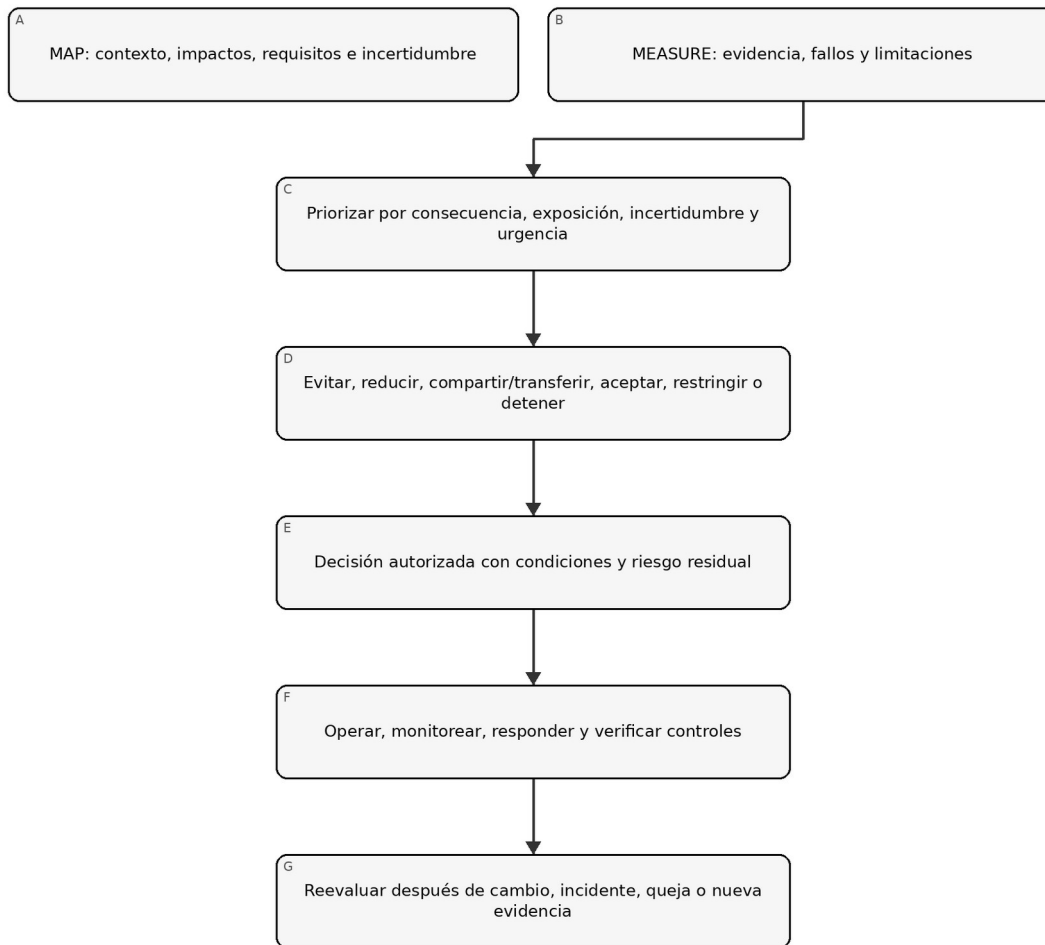


Figure 13. Chapter memory graphic

Explicación accesible: La administración combina el contexto de MAP con la evidencia de MEASURE, prioriza el riesgo, selecciona tratamiento y registra una decisión autorizada con condiciones y riesgo residual. La operación monitorea y verifica controles. Los cambios y señales del mundo real activan una nueva evaluación.

25.1 Registro de priorización

Priorice usando más que una puntuación genérica. Registre:

- consecuencia plausible y reversibilidad;
- población afectada, vulnerabilidad y escala;
- exposición, frecuencia y duración;
- probabilidad cuando pueda respaldarse;
- incertidumbre y calidad de la evidencia;
- fortaleza del control y detectabilidad;
- urgencia, incluidos incidentes activos o plazos legales;
- riesgo de modo común o concentración;
- compensaciones entre oportunidad y beneficio; y
- dependencias entre riesgos.

Una incertidumbre alta puede justificar controles más fuertes o un piloto más estrecho incluso cuando se desconoce la probabilidad.

25.2 Vista de portafolio

Agregue riesgos de IA entre sistemas sin perder la rendición de cuentas a nivel de sistema. La administración debe identificar:

- múltiples usos dependientes del mismo modelo/proveedor;
- fallos repetidos de controles;
- efectos acumulativos sobre la misma población;
- capacidad escasa de supervisión o validación;
- riesgo correlacionado de ciberseguridad, privacidad u operación;
- excepciones y decisiones de riesgo residual próximas a vencer; y
- sistemas cuya autonomía o escala combinada exceda los supuestos originales.

25.3 Cadencia de decisiones

Utilice revisión activada por eventos además de calendarios. Revise la prioridad cuando aparezca un cambio material, incidente, queja, fallo de evaluación, aviso de proveedor, desarrollo legal, cambio de tolerancia al riesgo o nueva población afectada.

26. Tratamiento del riesgo, controles, propiedad y planificación de acciones

El tratamiento debe cambiar la exposición real, el comportamiento o la capacidad de recuperación, no solo crear documentación.

26.1 Opciones de tratamiento

- Evitar: no iniciar, retirar una función o retirar el uso.
- Reducir: cambiar propósito, diseño, datos, modelo, autonomía, población, proceso o controles.
- Compartir/transferir: asignar obligaciones definidas mediante contrato o seguro, conservando la rendición de cuentas que no puede transferirse.
- Aceptar: autorizar riesgo residual dentro de autoridad y condiciones documentadas.
- Pilotar/restringir: limitar geografía, población, usuarios, datos, autonomía, duración o volumen para reunir evidencia de forma segura.
- Detener/rollback: suspender la operación o volver a un estado seguro conocido.

26.2 Registro de diseño de controles

Campo	Contenido mínimo
Riesgo/escenario	Causa-evento-consecuencia mapeados y partes afectadas
Objetivo	Exposición, fallo o consecuencia que aborda el control
Control	Actividad preventiva, detectiva, correctiva o de recuperación
Propietario/operador	Propietario responsable y persona/sistema que lo ejecuta
Activador/frecuencia	Continuo, por transacción, por liberación, periódico o por evento
Evidencia	Registro que demuestra diseño y operación
Umbral	Condición que causa acción o escalamiento
Dependencia	Datos, herramienta, proveedor, revisor o infraestructura necesaria
Limitación	Brecha o modo de falla conocido
Prueba	Cómo se evalúan la eficacia de diseño y la eficacia operativa
Riesgo residual	Lo que permanece después del control

26.3 Jerarquía de controles

Prefiera controles que eliminen o restrinjan el riesgo en la fuente antes de depender únicamente de que los usuarios detecten errores. Según el contexto:

78. eliminar el uso o capacidad peligrosa;
79. reducir alcance, autonomía, datos o acceso;
80. rediseñar arquitectura, modelo, flujo de trabajo o interfaz;
81. implementar controles técnicos y de proceso;
82. agregar supervisión humana competente y verificación independiente;
83. agregar advertencias, instrucciones y capacitación; y
84. monitorear, responder y proporcionar reparación.

La capacitación y los descargos rara vez son controles suficientes para comportamiento de sistemas de alta consecuencia.

26.4 Plan de acción

Cada elemento de remediación debe tener propietario, fecha de vencimiento, severidad, dependencia, criterios de aceptación, evidencia, método de repetición de prueba y ruta de escalamiento. Una fecha de vencimiento no reduce el riesgo actual; pueden requerirse restricciones interinas hasta verificar la remediación.

27. Decisiones de riesgo residual, excepciones y aceptación responsable

El riesgo residual es una decisión sobre la exposición restante después de la evidencia y los controles, no una etiqueta generada por una herramienta de puntuación.

27.1 Registro de aceptación

Registre:

- sistema/uso y versión exactos;
- alcance de la decisión, población, geografía y duración;
- riesgos, beneficios y partes afectadas relevantes;
- evidencia revisada e incertidumbre no resuelta;
- controles y condiciones operativas;
- elementos fallidos, inconclusos o no probados;
- justificación del riesgo residual;
- autoridad de decisión y competencia;
- aprobación, aprobación condicional, restricción o rechazo;
- fecha de vencimiento y revisión;
- activadores automáticos de reevaluación/detención; y
- disenso o posición minoritaria.

27.2 Niveles de autoridad

Alinee la autoridad de aceptación con la consecuencia. El riesgo bajo y acotado puede aceptarse por el propietario responsable dentro de la política. El riesgo moderado puede requerir aprobación multifuncional. El riesgo de alta consecuencia, regulado, sensible a safety o a nivel de portafolio puede requerir autoridad ejecutiva o designada por la junta y desafío independiente.

Nadie debe aceptar riesgo en nombre de las partes afectadas simplemente porque la organización obtenga un beneficio. Las obligaciones legales y no transferibles permanecen vinculantes.

27.3 Excepciones

Una excepción debe ser:

- estrecha y limitada en el tiempo;
- aprobada por personas autorizadas;
- explícita sobre el requisito incumplido;

- respaldada por análisis de riesgo;
- acompañada de controles compensatorios o restricciones;
- monitoreada;
- visible para funciones de aseguramiento; y
- vencida automáticamente salvo que se renueve mediante una nueva decisión.

27.4 Verificación de calidad de la decisión

Rechace o devuelva una decisión si la evidencia falta, no corresponde a la versión, venció, fue invalidada por cambio material, es internamente inconsistente o no puede respaldar el contexto afirmado. La “urgencia del negocio” debe registrarse como un factor, no utilizarse para borrar el riesgo.

28. Despliegue, liberación, restricción, detención, rollback y retiro

La liberación es una decisión de riesgo basada en evidencia para una configuración exacta, no el final de la gestión de riesgos.

28.1 Puerta de liberación

Manual 03 memory graphic 14

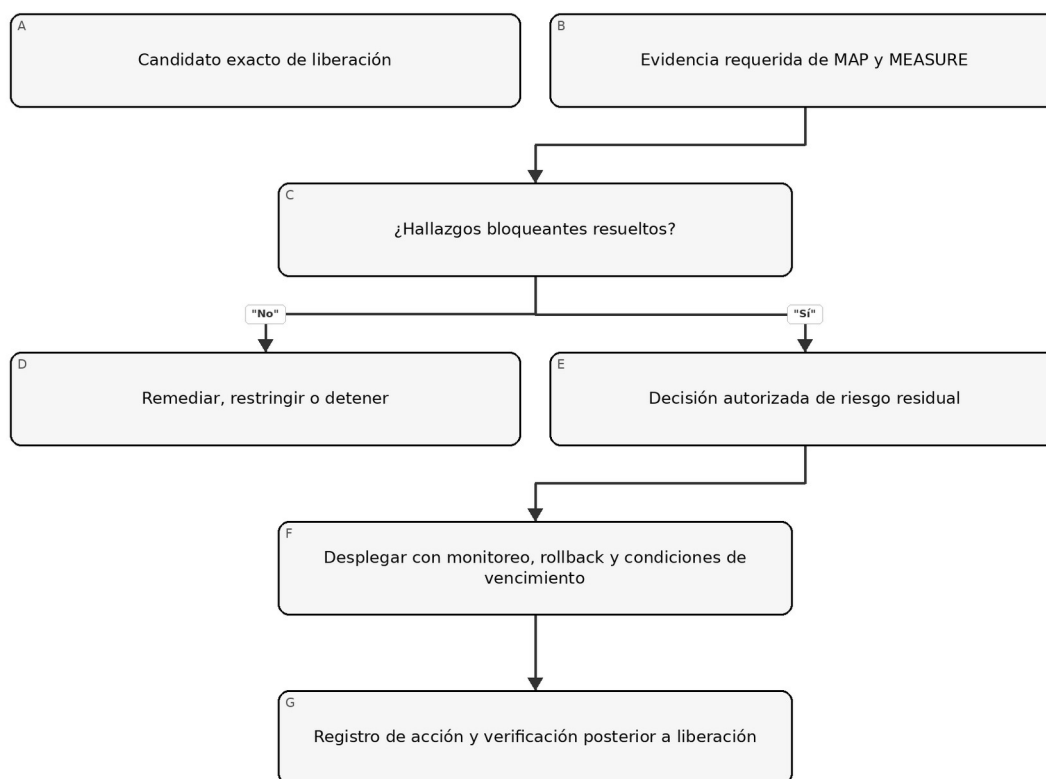


Figure 14. Chapter memory graphic

Explicación accesible: La puerta de liberación identifica el candidato exacto y la evidencia requerida. Los hallazgos bloqueantes conducen a remediación, restricción o detención. Cuando la evidencia respalda la decisión, una persona autorizada acepta el riesgo residual y el despliegue ocurre con condiciones de monitoreo y rollback. La liberación y el seguimiento quedan registrados.

28.2 Evidencia mínima de liberación

- propósito y contexto aprobados;
- nivel de riesgo actual;
- versiones exactas de modelo, datos, prompt/configuración, software y dependencias;
- resultados de evaluación requeridos y limitaciones;
- revisiones de ciberseguridad, privacidad, safety, accesibilidad y dominio según corresponda;
- evidencia del proveedor y condiciones contractuales;
- instrucciones para usuario y supervisión;
- preparación para monitoreo e incidentes;
- prueba de detención, rollback, fallback y recuperación;
- hallazgos no resueltos y condiciones aceptadas;
- aprobación de riesgo residual; y
- registro de liberación e identificadores de checksum/versión.

28.3 Despliegue progresivo

Utilice liberación por etapas o canary, poblaciones limitadas, menor autonomía, límites de tasa, puertas de aprobación, proceso humano paralelo o evaluación en sombra cuando esto reduzca la incertidumbre sin exponer a las personas a un riesgo inaceptable.

28.4 Detención y rollback

Defina activadores objetivos, autoridad y capacidad técnica. Ejemplos:

- daño grave o daño inminente creíble;
- compromiso de seguridad o exposición de datos sensibles;
- degradación material del desempeño o de subgrupos;
- salidas dañinas o prohibidas repetidas;
- pérdida de supervisión humana requerida;
- evidencia requerida inválida o faltante;
- cambio no aprobado de proveedor/modelo;
- falla de monitoreo o logging para un control crítico; y
- prohibición legal o contractual vinculante.

Pruebe la detención y el rollback antes de depender de ellos. Confirme revocación de identidad, acciones en cola, reconciliación downstream, comunicaciones y validación de restauración.

28.5 Retiro

El retiro debe abordar retención/eliminación de datos y registros, acceso a modelo y credenciales, integraciones, comunicación a usuarios, terminación de proveedor, decisiones pendientes, legal hold, transferencia de conocimiento, archivo, detención del monitoreo y confirmación de que el sistema ya no actúa.

29. Monitoreo, deriva, incidentes, quejas, apelaciones y acción correctiva

La evidencia operativa determina si los supuestos y controles continúan siendo válidos después de la liberación.

29.1 Diseño de monitoreo

Para cada medida, defina:

- pregunta y riesgo abordado;
- fuente de datos y límite de privacidad;
- población y versión;
- cálculo o rúbrica;
- línea base y umbral;
- propietario y revisor;
- frecuencia o latencia;
- acción cuando se supera el umbral;

- limitación de falso positivo/falso negativo; y
- retención de evidencia.

Monitoree el comportamiento del sistema, interacción humana, controles, resultados que afectan a personas, cambios de proveedores y el propio sistema de monitoreo.

29.2 Deriva y degradación

Distinga cambios en datos de entrada, población, concepto/relación, comportamiento del modelo, flujo de trabajo, usuarios, ambiente y resultados. Una métrica puede permanecer estable mientras cambia la consecuencia, por lo que combine señales cuantitativas con incidentes, quejas, anulaciones y revisión del dominio.

29.3 Proceso de incidentes

Manual 03 memory graphic 15

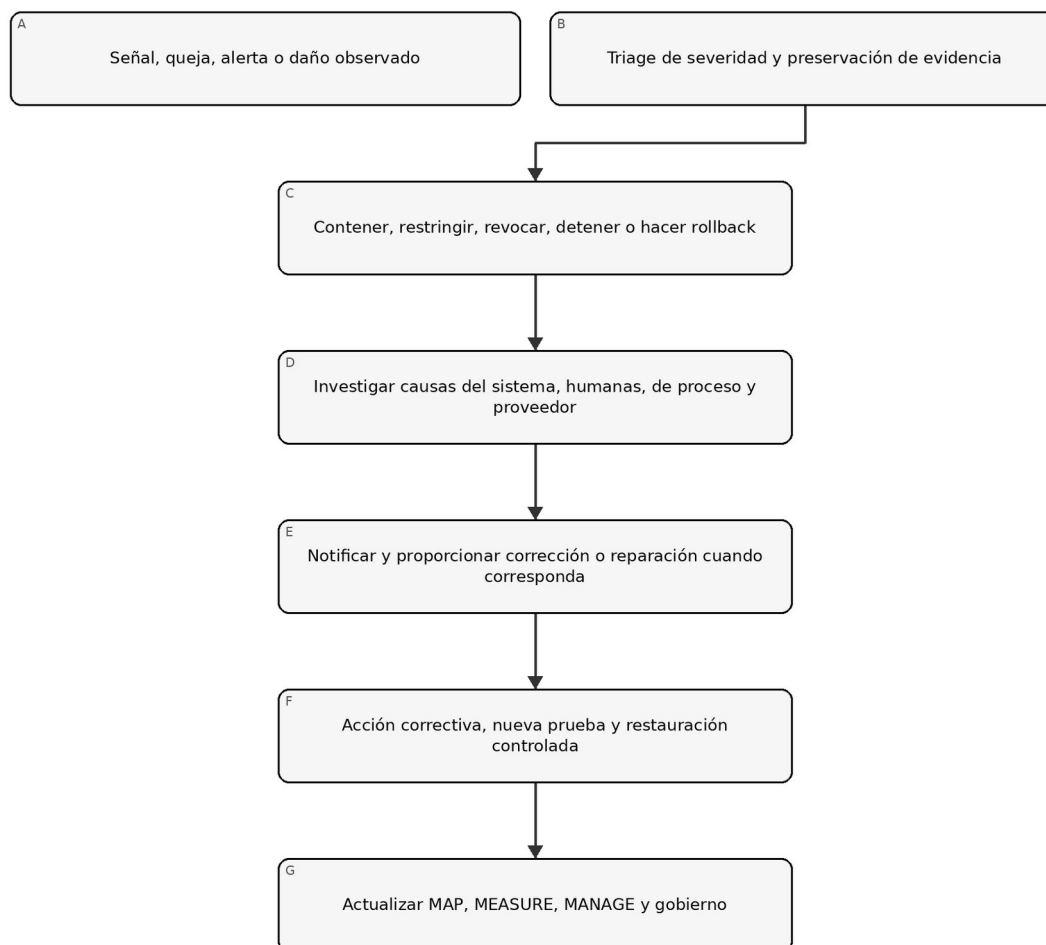


Figure 15. Chapter memory graphic

Explicación accesible: Un incidente comienza con una señal o queja, seguido de triage y preservación de evidencia. La organización contiene el problema, investiga causas técnicas y organizacionales, proporciona la notificación o reparación requerida, verifica la acción correctiva y actualiza todo el ciclo de gestión de riesgos.

29.4 Quejas, apelaciones y reparación

Trate las quejas como evidencia de riesgo, no solo como tickets de servicio al cliente. Vincúlelas a la versión y contexto del sistema, proteja a quienes presentan quejas, mantenga canales accesibles, evite represalias, defina niveles de servicio, habilite revisión humana competente y rastree patrones repetidos.

29.5 Acción correctiva

Separe la corrección inmediata de la acción correctiva sobre causa raíz. Registre:

- problema y consecuencia;
- contención/corrección;
- análisis de causa en tecnología, personas, procesos y gobierno;
- alcance sistémico;
- propietario de la acción y fecha de vencimiento;
- verificación de implementación;
- repetición de prueba de eficacia;
- monitoreo de recurrencia; y
- actualizaciones a sistemas relacionados, políticas, capacitación y controles de proveedores.

30. Cambios, proveedores, IA generativa y gobierno de sistemas agénticos

Un cambio material invalida los supuestos y la evidencia afectados hasta que se analice su impacto.

30.1 Clases de cambio

Revise cambios en:

- propósito o límite de uso prohibido;
- población, geografía, idioma o escala;
- fuente de datos, característica, retención o transformación;
- modelo, proveedor, versión, fine-tuning o prompt;
- software, herramienta, integración o permiso;
- autonomía o acción downstream;
- interfaz, aviso o supervisión humana;
- proveedor/subprocesador y contrato;
- monitoreo y logging; y
- requisito aplicable o tolerancia al riesgo.

Clasifique los cambios como no materiales, materiales con revisión limitada o materiales que requieren reevaluación completa. Conserve la justificación y el revisor.

30.2 Control de cambios de proveedor

Exija notificación cuando sea factible, pero suponga que los proveedores pueden cambiar el comportamiento sin aviso completo. Utilice fijación de versión, pruebas de regresión, monitoreo, derechos contractuales, actualización de evidencia, fallback y planificación de salida de manera proporcional a la dependencia.

30.3 Integración del perfil de IA generativa

Cuando la IA generativa esté dentro del alcance, aplique NIST AI 600-1 como perfil complementario al proceso general de AI RMF. Evalúe las familias de riesgo GenAI y las acciones del perfil que sean aplicables sin tratar cada acción como universalmente requerida.

Como mínimo considere:

- confabulación y contenido no respaldado;
- contenido peligroso, de odio o abusivo;
- preocupaciones de privacidad de datos y propiedad intelectual;
- integridad y procedencia de información;
- ciberseguridad y ataques a prompts/herramientas;

- dependencia humana excesiva y efectos emocionales o sociales;
- sesgo perjudicial y homogeneización;
- habilitación de uso indebido y abuso a escala;
- efectos ambientales y de recursos cuando sean materiales;
- riesgo de cadena de valor e integración de componentes; y
- limitaciones de evaluación.

Manual 04 proporciona una implementación más profunda de NIST AI 600-1.

30.4 Sistemas agénticos

Para agentes autónomos o que utilizan herramientas, implemente y pruebe:

- identidades estrechas y mínimo privilegio;
- listas permitidas de herramientas y acciones prohibidas;
- límites de transacción, tiempo, tasa y recursos;
- confirmación humana para acciones de consecuencia;
- límites de confianza de entrada/contenido;
- aislamiento del ambiente;
- trazas completas de acciones;
- controles de memoria y retención;
- revocación determinista y parada de emergencia;
- rollback y reconciliación downstream; y
- responsabilidad explícita por decisiones delegadas.

31. Métricas, aseguramiento, auditoría interna y mejora continua

El aseguramiento pregunta si el gobierno y los controles están diseñados y operan eficazmente; no certifica que el riesgo haya sido eliminado.

31.1 Métricas de administración

Use medidas vinculadas a decisiones, como:

- usos activos de IA con propietario, nivel y aprobación vigentes;
- sistemas materiales vinculados a evidencia de evaluación de la versión desplegada;
- fallos de alta severidad y antigüedad de remediación;
- excepciones y decisiones de riesgo residual vencidas;
- incidentes, quejas, apelaciones, anulaciones y recurrencia;
- violaciones de umbral y tiempo de respuesta;
- evidencia de proveedores y cambios no revisados;
- repetición de pruebas de eficacia de acción correctiva; y
- sistemas restringidos, detenidos o rediseñados porque la evidencia era inadecuada.

Evite recompensar el volumen de documentos o suprimir el reporte de incidentes.

31.2 Aseguramiento de controles

Pruebe ambos:

- eficacia de diseño: el control, si opera como fue diseñado, aborda el riesgo en contexto; y
- eficacia operativa: el control realmente operó para la población y período requeridos, produjo evidencia, detectó excepciones y causó la acción requerida.

31.3 Auditoría interna

Un programa de auditoría debe definir alcance basado en riesgo, criterios, competencia, independencia, muestreo, evidencia, hallazgos, reporte y seguimiento. Los auditores no deben auditar su propio trabajo sin salvaguardas. Conserve la distinción entre auditoría interna, evaluación técnica, revisión de compliance, certificación y examen regulatorio.

31.4 Clasificación de hallazgos

Clasifique hallazgos con base en consecuencia, alcance sistémico, falla de control, recurrencia, evidencia y urgencia. Cada hallazgo debe identificar criterio, condición, evidencia, impacto/riesgo, propietario, acción, fecha de vencimiento y prueba de cierre.

31.5 Ciclo de aprendizaje

Utilice incidentes, near misses, quejas, auditorías, eventos de proveedores y controles exitosos para actualizar inventario, criterios de riesgo, escenarios, métodos de evaluación, umbrales, capacitación, estándares de diseño y decisiones de portafolio.

32. Hojas de ruta de implementación, madurez, perfiles y revisión del marco

Las organizaciones deben comenzar con un mínimo controlado y agregar profundidad cuando el riesgo, la complejidad y la evidencia lo exijan.

32.1 Hoja de ruta Essential

Primeros 30 días

- designar liderazgo responsable de riesgo de IA;
- emitir reglas interinas de usos aprobados/prohibidos;
- comenzar descubrimiento e inventario de IA;
- definir un método simple de enrutamiento de riesgos;
- identificar usos materiales existentes;
- establecer contactos de incidentes y detención; y
- seleccionar un conjunto pequeño de plantillas de evidencia.

Días 31–90

- completar contexto y evaluación mínima para usos materiales;
- asignar autoridad de riesgo residual;
- implementar verificaciones de proveedores y cambios;
- documentar instrucciones de usuario/supervisión;
- definir umbrales de monitoreo; y
- remediar o restringir usos que carezcan de evidencia respaldable.

Meses 4–12

- reconciliar el inventario periódicamente;
- probar controles y acciones correctivas;
- mejorar el manejo de incidentes/quejas;
- construir métricas de administración;
- realizar revisión interna basada en riesgo; y
- actualizar el perfil objetivo.

32.2 Hoja de ruta Structured

Agregue gobierno formal, puertas multifuncionales del ciclo de vida, TEVV controlado, versión/linaje, evidencia de proveedores, revisión de privacidad/ciberseguridad/accesibilidad/dominio, métricas operativas, revisión periódica por la administración, auditoría interna y retención controlada de evidencia.

32.3 Hoja de ruta Enhanced

Agregue supervisión ejecutiva/de junta, validación independiente, participación de partes afectadas, evaluación adversaria y de estrés, monitoreo continuo de riesgos clave, detención/rollback ensayados, análisis de concentración de portafolio, vigilancia mejorada de proveedores y vencimiento formal de riesgo residual.

32.4 Modelo de madurez

Nivel	Estado observable
0 — No controlado	El uso de IA es desconocido o no gestionado; faltan propiedad y evidencia
1 — Inicial	Existen inventario básico, política, propietario y revisión caso por caso
2 — Repetible	Enrutamiento de riesgo, puertas del ciclo de vida, evaluación y evidencia se utilizan consistentemente
3 — Medido	Métricas operativas, pruebas de controles, revisión de proveedores/cambios y decisiones administrativas están vinculadas
4 — Adaptativo	Incidentes, evidencia de partes afectadas, riesgo de portafolio y aseguramiento impulsan sistemáticamente la mejora

La madurez no es una certificación. Un proceso de Nivel 4 aún puede tomar una mala decisión sobre un sistema, y una organización pequeña puede operar controles fuertes sin una burocracia elaborada.

32.5 Perfiles actual y objetivo

Cree un perfil actual que describa resultados y evidencia reales y un perfil objetivo que describa resultados deseados con base en riesgo y obligaciones. El plan de brechas debe identificar prioridad, propietario, recursos, dependencias, fecha, evidencia y restricción interina.

32.6 Protocolo de revisión del marco

Cuando NIST publique un AI RMF revisado:

85. congele el candidato de liberación actual del Manual 03;
86. verifique la publicación oficial final y la versión;
87. compare funciones, categorías, subcategorías, terminología y orientación;
88. clasifique impactos sobre capítulos, plantillas, gráficos, perfiles y crosswalks;
89. actualice primero la fuente controlada en inglés;
90. reabra las revisiones de fuente y técnicas afectadas;
91. vuelva a localizar el significado modificado mediante localización controlada revisada por humanos;
92. regenere artefactos DOCX/PDF y repita QA de accesibilidad, visual y seguridad; y
93. publique un registro de cambio versionado sin sobrescribir silenciosamente la línea base anterior.

32.7 Límite final de implementación

Implementar este manual puede fortalecer el gobierno de riesgos y la evidencia. No demuestra que un sistema de IA sea confiable, no elimina el daño, no satisface todas las leyes, no establece conformidad con ISO/IEC 42001, no crea certificación ni constituye una opinión de auditoría. La organización sigue siendo responsable del sistema real, contexto, obligaciones, decisiones y efectos.

Punto de control Parte 4: Los capítulos 25–32 completan el ciclo operativo GOVERN–MAP–MEASURE–MANAGE y lo conectan con despliegue, operaciones, incidentes, aseguramiento, hojas de ruta y revisión controlada del marco.